



Okta, Inc.

SYSTEM AND ORGANIZATION CONTROLS (SOC) 2 TYPE 2 REPORT

DESCRIPTION OF OKTA'S IDENTITY AS A SERVICE ("IDaaS") SYSTEM RELEVANT TO SECURITY, AVAILABILITY, AND CONFIDENTIALITY

For the period January 1, 2024 through November 30, 2024

George Sajonian, george.sajonian@solidghosttechnology.com, 2025-04-07T15:45:12.402Z



TABLE OF CONTENTS

Section 1: Okta's Management Assertion	1
Section 2: Independent Service Auditor's Assurance Report	3
Section 3: Description of Okta's Identity as a Service ("IDaaS") System Relevant to Security, Availability, and Confidentiality	9
Section 4: Okta's Controls, Trust Service Criteria, Service Auditor's Test of Controls, and Test Results	43

George Sajonian, george.sajonian@solidigmtechnology.com, 2025-04-01T15:45:12-0402Z

Section 1: Okta's Management Assertion

George Sajonian, george.sajonian@solidminttechnology.com, 2025-04-07T15:45:12.402Z



Okta's Management Assertion

We have prepared the accompanying description titled "Description of Okta's Identity as a Service ("IDaaS") System Relevant to Security, Availability, and Confidentiality" (Description) of Okta, Inc. ("Service Organization" or "Okta") in accordance with the criteria for a description of a service organization's system set forth in the Description Criteria DC section 200 *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2 Report* (Description Criteria). The Description is intended to provide report users with information about the Okta's Identity as a Service System ("System" or "IDaaS") that may be useful when assessing the risks arising from interactions with the System, particularly information about system controls that the Service Organization has designed, implemented and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to security, availability, and confidentiality (applicable trust services criteria) set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy*, in the AICPA Trust Services Criteria.

Okta uses Amazon Web Services ("AWS" or "subservice organization") to provide physical safeguards, environmental safeguards, infrastructure support and management, and storage services. The Description indicates that complementary controls at AWS that are suitably designed and operating effectively are necessary, along with controls at Okta, to achieve Okta's service commitments and system requirements, based on the applicable trust services criteria. The Description presents Okta's controls and the types of complementary subservice organization controls assumed in the design of Okta's controls. The Description does not disclose the actual controls at AWS.

We confirm, to the best of our knowledge and belief, that:

- a. The Description presents the System that was designed and implemented throughout the period January 1, 2024 to November 30, 2024 in accordance with the Description Criteria.
- b. The controls stated in the Description were suitably designed throughout the period January 1, 2024 to November 30, 2024 to provide reasonable assurance that Okta's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout the period January 1, 2024 to November 30, 2024, and if the carved-out subservice organization applied the complementary controls assumed in the design of Okta's controls throughout the period January 1, 2024 to November 30, 2024.
- c. The Okta controls stated in the Description operated effectively throughout the period January 1, 2024 to November 30, 2024 to provide reasonable assurance that Okta's service commitments and system requirements were achieved based on the applicable trust services criteria if the complementary carved-out subservice organization controls assumed in the design of Okta's controls operated effectively throughout that period.

Management of Okta, Inc.

Section 2: Independent Service Auditor's Assurance Report

George Sajonian, george.sajonian@sudigittechnology.com, 2025-04-07T15:45:12.402Z

Independent Service Auditor's Assurance Report

To the Management of Okta, Inc.

Scope

We have examined Okta's accompanying description titled "Description of Okta's Identity as a Service ("IDaaS") System Relevant to Security, Availability, And Confidentiality" of its IDaaS system for its cloud-based identity and access management ("IAM") and single sign-on ("SSO") service throughout the period January 1, 2024 to November 30, 2024 (Description) in accordance with the criteria for a description of a service organization's system set forth in the Description Criteria DC section 200 2018 *Description Criteria for a Description of a Service Organization's System in a SOC 2 Report*, (Description Criteria) and the suitability of the design and operating effectiveness of controls stated in the Description throughout the period January 1, 2024 to November 30, 2024 to provide reasonable assurance that the service commitments and system requirements were achieved based on the trust services criteria relevant to security, availability, and confidentiality (applicable trust services criteria) set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy*, in the AICPA Trust Services Criteria.

Okta uses Amazon Web Services ("AWS" or "subservice organization") to provide physical safeguards, environmental safeguards, infrastructure support and management, and storage services. The Description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at Okta, to provide reasonable assurance that Okta's service commitments and system requirements are achieved based on the applicable trust services criteria. The description presents Okta's system; its controls relevant to the applicable trust services criteria; and the types of complementary subservice organization controls that the service organization assumes have been implemented, suitably designed, and are operating effectively at AWS. The Description does not disclose the actual controls at AWS. Our examination did not include the services provided by AWS and we have not evaluated whether the controls management assumes have been implemented at AWS have been implemented or whether such controls were suitably designed and operating effectively throughout the period January 1, 2024 to November 30, 2024.

Okta's responsibilities

Okta is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that its service commitments and system requirements were achieved. Okta has provided the accompanying assertion titled, Okta's Management Assertion (Assertion) about the presentation of the Description based on the Description Criteria and the suitability of design and operating effectiveness of controls stated therein to provide reasonable assurance that the service commitments and system requirements would be achieved based on the applicable trust services criteria. Okta is responsible for (1) preparing the Description and Assertion; (2) the completeness, accuracy, and method of presentation of the Description and Assertion; (3) providing the services covered by the Description; (4) selecting the trust services categories addressed by the engagement and stating the applicable

trust services criteria and related controls in the Description; (5) identifying the risks that threaten the achievement of the service organization's service commitments and system requirements; and (6) designing, implementing, and documenting controls that are suitably designed and operating effectively to achieve its service commitments and system requirements.

Service auditor's responsibilities

Our responsibility is to express an opinion on the presentation of the Description and on the suitability of design and operating effectiveness of controls stated therein to achieve the service organization's service commitments and system requirements based on our examination.

Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants ("AICPA") and International Standard on Assurance Engagements 3000 (Revised), Assurance Engagements Other Than Audits or Reviews of Historical Financial Information, issued by the International Auditing and Assurance Standards Board. Those standards require that we plan and perform our examination to obtain reasonable assurance about whether, in all material respects, (1) the Description is presented in accordance with the Description Criteria, and (2) the controls stated therein were suitably designed and operating effectively to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria throughout the period January 1, 2024 to November 30, 2024. The nature, timing, and extent of the procedures selected depend on our judgment, including an assessment of the risk of material misstatement, whether due to fraud or error. We believe that the evidence we have obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

An examination of a description of a service organization's system and the suitability of the design and operating effectiveness of controls involves:

- obtaining an understanding of the system and the service organization's service commitments and system requirements
- assessing the risks that the Description is not presented in accordance with the Description Criteria and that controls were not suitably designed or operating effectively based on the applicable trust services criteria
- performing procedures to obtain evidence about whether the Description is presented in accordance with the Description Criteria
- performing procedures to obtain evidence about whether controls stated in the Description were suitably designed to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria

- testing the operating effectiveness of those controls to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria
- evaluating the overall presentation of the Description

Our examination also included performing such other procedures as we considered necessary in the circumstances.

Our examination was not conducted for the purpose of evaluating the performance or integrity of Okta's AI services. Accordingly, we do not express an opinion or any other form of assurance on the performance or integrity of Okta's AI services.

We are required to be independent of Okta and to meet our other ethical responsibilities, in accordance with the relevant ethical requirements related to our examination engagement. We have complied with such independence and other ethical requirements and applied the AICPA's Statements on Quality Control Standards.

We apply International Standard on Quality Management 1, Quality Management for Firms that Perform Audits or Reviews of Financial Statements, or Other Assurance or Related Services engagements, which requires that we design, implement and operate a system of quality management including policies or procedures regarding compliance with ethical requirements, professional standards and applicable legal and regulatory requirements.

Inherent limitations

The Description is prepared to meet the common needs of a broad range of report users and may not, therefore, include every aspect of the system that individual users may consider important to meet their informational needs.

There are inherent limitations in the effectiveness of any system of internal control, including the possibility of human error and the circumvention of controls. Because of their nature, controls at a service organization may not always operate effectively to provide reasonable assurance that the service organization's service commitments and system requirements are achieved based on the applicable trust services criteria. Also, the projection to the future of any evaluation of the presentation of the Description, or conclusions about the suitability of the design or operating effectiveness of the controls to meet the applicable trust services criteria, is subject to the risk that the system may change or that controls at a service organization may become ineffective.

Description of tests of controls

The specific controls we tested, and the nature, timing, and results of those tests are listed in the accompanying Okta's Controls, Service Auditor's Test of Controls, and Test Results (Description of Tests and Results).

Opinion

In our opinion, in all material respects:

- a. the Description presents the Okta Identity as a Service system that was designed and implemented throughout the period January 1, 2024 to November 30, 2024 in accordance with the Description Criteria.
- b. the controls stated in the Description were suitably designed January 1, 2024 to November 30, 2024, to provide reasonable assurance that Okta's service commitments and system requirements would be achieved based on the applicable trust services criteria if its controls operated effectively throughout that period and if the subservice organization applied the complementary controls assumed in the design of Okta's controls throughout that period.
- c. the controls stated in the Description operated effectively throughout the period January 1, 2024 to November 30, 2024 to provide reasonable assurance that Okta service commitments and system requirements were achieved based on the applicable trust services criteria if the complementary subservice organization assumed in the design of Okta's controls operated effectively throughout that period.

Restricted use

This report, including the description of tests of controls and results thereof in the Description of Tests and Results is intended solely for the information and use of Okta, user entities of Okta's IDaaS system during some or all of the period January 1, 2024 to November 30, 2024 and prospective user entities, independent auditors and practitioners providing services to such user entities, and regulators who have sufficient knowledge and understanding of the following:

- the nature of the service provided by the service organization
- how the service organization's system interacts with user entities, subservice organizations, or other parties
- internal control and its limitations
- complementary subservice organization controls and how those controls interact with the controls at the service organization to achieve the service organization's service commitments and system requirements



- user entity responsibilities and how they interact with related controls at the service organization
- the applicable trust services criteria
- the risks that may threaten the achievement of the service organization's service commitments and system requirements and how controls address those risks

This report is not intended to be, and should not be, used by anyone other than these specified parties.

Ernst & Young LLP

January 30, 2025

Section 3: Description of Okta's Identity as a Service ("IDaaS") System Relevant to Security, Availability, and Confidentiality



Description of Okta's Identity as a Service ("IDaaS") System Relevant to Security, Availability, and Confidentiality

Company Background

Okta, Inc. ("Okta" or "The Company") is an independent provider of identity for an enterprise. The Okta Identity Cloud enables organizations to secure and manage their extended enterprise and transform their customers' experiences. Okta was founded in 2009 and is based in San Francisco, California.

The Okta Identity Cloud is used by organizations in two distinct ways. Okta's information technology ("IT") products enable organizations to deploy, manage, automate workflows, secure applications, manage provisioning, and support users across their IT environments. Additionally, Okta's application programming interface ("API") products allow developers to similarly leverage a robust set of capabilities to quickly build custom web and mobile application experiences leveraging Okta's Identity Cloud as the underlying identity platform.

Scope and Purpose

The System and Organization Controls ("SOC") 2 report is an examination of the internal controls of Okta, Inc. ("Okta" or "The Company") as it relates to the Okta Identity as a Service ("IDaaS") System and Okta Identity Governance ("OIG") System (hereinafter, "the Systems") relevant to Security, Availability, and Confidentiality trust service criteria as set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy* established by the American Institute of Certified Public Accountants ("AICPA").

This section of the report was prepared by the management of Okta in accordance with the criteria for a description of a service organization's system set forth in the Description Criteria DC section 200 *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2 Report* (Description Criteria) and is intended to provide user organizations with information about the System relevant internal controls to achieve the service commitments and system requirements based on the application trust service criteria for Security, Availability, and Confidentiality for the period January 1, 2024 to November 30, 2024. It does not and is not intended to encompass all aspects of the services, procedures, or controls performed by Okta.

Description of Products and Services

Okta's suite of products and solutions (referred to herein as "Okta platform", "Core Identity Platform", or "IDaaS") includes the following:

Identity as a Service ("IDaaS")

IDaaS is a cloud-based identity and access management ("IAM") and single sign-on ("SSO") service designed, built, tested, and maintained by Okta. IDaaS features include user identity management, SSO login, active directory ("AD"), lightweight directory access protocol ("LDAP") integration, centralized provisioning and de-provisioning of users, multi-factor authentication, mobile identity management, and flexible policies for security and control.



All of Okta's features are brought together through a network of pre-integrated applications called the Okta Integration Network ("OIN"). The OIN provides diverse integration options with business and consumer applications, enabling SSO login for every application user. These application connection integrations are continuously validated and maintained. Okta and its service integration partners complete the upfront work of integrating application-connectors into the application network. Okta's cloud services platform, which is the core of Okta's IDaaS, contains the functionality for SSO, user identity management, and system activity reporting. The core capabilities of IDaaS include the following:

- SSO capabilities are achieved through federated user authentication. If the vendor supports security assertion markup language ("SAML") 1.1 or 2.0, Okta will act as a SAML identity provider ("IdP"), respond to SAML requests from those applications with a SAML assertion and facilitate secure user authentication. Okta also supports OAuth and OpenID Connect, as well as proprietary SSO protocols. For Software as a Service ("SaaS") applications that do not provide support for federated user authentication, Okta has developed a secure web authentication ("SWA") technology. Credentials are stored using a strong advanced encryption standard ("AES"). Okta executes a secure login sequence specific to a vendor leveraging user credentials to complete the login.
- IDaaS provides pre-integrated provisioning capabilities which allows integration for centralized provisioning that support coarse-grained to fine-grained management of application user accounts. IDaaS has real-time user provisioning triggered by the client's preferred human resources ("HR") system or application. The provisioning functionality also includes the following features:
 - Integration to AD or LDAP including extended rich profiles, group push, license, and role assignment
 - Automatically detects different users' attributes in different applications, along with application entitlements
 - Matches directory groups with application groups, assigns and revokes licenses, and creates a custom offboarding process
 - Extends the power of provisioning to clients' custom applications by using the system for cross-domain identity management ("SCIM")
 - Use Okta's API to make any application the profile master
 - Get automated provisioning for any application using the cloud or on-prem provisioning software development kit ("SDK")
 - Customizable directory for user groups and devices with extensible user profile, group profile, device profile
 - Master different attributes from different sources, like first and last name from HR and email from exchange
 - Create a single source of truth by mastering attributes in the Okta profile from any authoritative source with ability for identity and profile sync



- Centrally manage groups such as Google Workspace (formerly G Suite), Box, and AD in Okta through group mastering and group membership rules
 - Create multi-step approval with specific people or groups based on custom access request and deprovisioning workflow
 - Identity governance with a focus on access and ease of use which provides account and entitlement reporting with comprehensive data
 - Detect rogue or orphan accounts
- Multi-factor authentication is provided as a core feature of the identity management services. Functionality is built by Okta with the same focus on flexibility, security, and ease of use applied to other aspects of the product and comes bundled with the Okta solution. No third-party products are required although Okta integrates with third-party multi-factor authentication products. Integrations with other multi-factor authentication is not in-scope in this report.
 - Application integration capability provides a complete solution that does not require custom extensions into each target application, device, or object. Key to Okta's solution is the OIN, which provides thousands of public and private application integrations built and maintained by Okta, that administrators can deploy in minutes.
 - Mobile identity provides unrestricted, easy access to authenticate mobile enterprise applications from any device while ensuring the same or an increase in security compared with what is available in the managed desktop world. Whether personal, corporate, tablets, smartphones, mobile web, or native applications, Okta has the technology to secure employees' mobile identity.
 - Mobile application integration is seamless, whether they are Hypertext Markup Language ("HTML") 5 web applications optimized for mobile platforms, native iOS, or Android applications. Mobile web applications can use industry standard SSO or Okta's SWA SSO technology.
 - Feature rich APIs that aim to make it easy to connect to and use any of Okta's capabilities programmatically, whether for software developers who want to use Okta as an identity layer for their applications or IT administrators who require a high level of customization.
 - Okta captures a comprehensive set of events and states including user import, application assignment, activation, and deactivation, Okta or application login, and application configuration changes. The data is captured in real time and maintained historically to support both interactive troubleshooting as well as detailed reporting. Such data is available to customers through the administrative portal in an industry-standard format over a secure connection (i.e., comma-separated values [CSV] or logs).

Okta Identity Governance ("OIG")

OIG is a Software as a Service ("SaaS") delivered, unified identity and access management ("IAM"), and governance solution. It includes three main features:



- **Access Request** automates the process of requesting access to applications and resources. It offers self-services capabilities through integrations with collaboration tools to automatically route user requests to one or more reviewers for approval and auto-provisioning of access.
- **Access Certification** campaigns offer a process for creating audit campaigns to periodically review user access to critical resources and approve or revoke access automatically.
- **Out-of-the-Box Reporting capabilities** help meet audit and compliance requirements. They provide visibility into past certification campaigns. They also provide administrators insights into which users have access to which resources, who approved the access, and how the access was provisioned.

The OIG product is delivered through the rich integration of multiple Okta products and features to provide enhanced user lifecycle management and create complex user access workflows. Specifically, the OIG product is delivered through the integration of IDaaS, Okta Workflows, and Okta Inbox. The OIG product is supported by controls within each of the respective products mentioned above. IDaaS is covered in this report, however, Okta Workflows and Okta Inbox are covered in their own respective attestation reports.

The feature set known as Identity Governance Administration ("IGA") is architected and maintained within the same systems and infrastructure as IDaaS. The controls in place to secure the IDaaS platform also secure the IGA components of the OIG product. The controls securing the IGA features are included in the procedures performed for IDaaS and is captured in this report.

Principal Service Commitments and System Requirements

Okta designs its processes and procedures to meet its objectives and commitments. Those objectives are based on the service commitments that Okta makes to user entities, the laws and regulations that govern the provisioning of the company's products, and the operational and compliance requirements that Okta has established for its products and services.

Security, availability, and confidentiality commitments to user entities are documented and communicated in Okta's Terms of Service and Privacy Policy, which are available to end users on Okta's public website. The Terms of Service and Privacy Policy are also described and communicated on Okta's sign-up page. The description of the service offering and the products delineating the boundaries and describing relevant components is also documented on the Okta's intranet and the customer-facing website.

Security, availability, and confidentiality commitments are standardized and include, but are not limited to the following:

- **Product Security** - Okta has a range of security controls designed to keep the Systems secure, protect customers' data against unauthorized access, and guide necessary changes. These controls include, but are not limited to, implementing security processes and tools for change, vulnerability, and incident management to prevent, detect, and remediate security threats and vulnerabilities, as well as the use of encryption technologies to protect customer data at rest and in transit.



- **System Availability** - Okta helps ensure its systems' availability to customers by using cloud hosting in multiple availability zones across AWS regions, maintains optimal infrastructure performance through continuous monitoring, and establishes backups and disaster recovery plans for quick and effective recovery in case of an incident.
- **Data Security and Confidentiality** - Security and confidentiality controls at Okta are designed to address relevant criteria to protect confidential information. Such controls include establishing and maintaining a data classification and data handling policy, business continuity plan, risk assessment process, and proper access management to restrict access to customers' data.

Changes to system and controls

There were no significant changes to the description of the system and controls for Okta IDaaS since the prior reporting period.

Components of the System

A system is designed, implemented, and operated to achieve specific business objectives in accordance with management-specified requirements. The purpose of the system description is to delineate the boundaries of the system, which includes the products and services outlined above and the five components described below: infrastructure, software, people, procedures, and data.

Infrastructure

Okta has outsourced infrastructure resource requirements for the Okta platform to Amazon Web Services ("AWS"). Okta views the use of public cloud solutions as a strategic advantage, that enables the Company to react to changing market trends and deploy services faster than traditional in-house data center management. Okta utilizes multiple AWS regions and multiple availability zones within each region for redundancy purposes to help ensure the availability of the platform.

Okta does not own or maintain any of the hardware located in the AWS data centers and operates under a shared security responsibility model. AWS is responsible for the security of the underlying cloud infrastructure (i.e., physical infrastructure, geographical regions, availability zones, edge locations, operating, managing and controlling the components from the host operating system, virtualization layer, and storage). Okta is responsible for securing the Okta platform deployed in AWS (i.e., customer data, applications, identity access management, operating system and network firewall configuration, network traffic, server-side encryption).

Production servers and client-facing applications are logically and physically secured from Okta's internal corporate information systems. The maintenance of Okta's information systems, production systems, and production environment for the Okta platform is managed by Okta's IT system administrators and Operations department, and Okta's Engineering and Operations department.

The production application databases are made up of three levels: entity, reporting, and transaction, which allow for high performance and tuning of specific application features. Databases are configured to replicate across AWS availability zones with supporting backup databases replicated from the primary database.



The in-scope hosted infrastructure also consists of multiple supporting tools, as shown in the table below:

Primary Infrastructure			
Production Application	Business Function Description	Operating System Platform and Database	Physical Location
IDaaS OIG	Okta's web-based application that provides secure identity management and single sign-on	Amazon Machine Image ("AMI") Apache Tomcat; Redis; MySQL	Multiple AWS regions
AWS management console	Cloud computing platform used to manage application service for deployment and operation of the Okta platform	N/A	Multiple AWS regions
Amazon Elastic Compute Cloud (Amazon EC2)	Virtualized network and processing infrastructure to host Okta	Linux (Ubuntu & Amazon Linux)	Multiple AWS regions
VPN	Secure remote access to the production environment	Palo Alto Network VPN	Multiple AWS regions

Software

The following software, infrastructure services, and tools are utilized in support of the control environment and delivery of the Systems:

- Amazon GuardDuty - threat detection service that continuously monitors malicious activity and unauthorized behavior to protect Okta AWS accounts and workloads
- Artifactory - development image deployment tool
- AWS CloudTrail - web service that records and logs AWS API calls. The recorded information includes the API caller, time, source IP address request parameters, and response elements
- AWS Identity Center - web service utilized to grant roles, users, and groups with permissions that allow and deny access to specific Okta AWS resources
- AWS Key Management Service (AWS "KMS") - managed service used to create and control encryption keys used to encrypt data used by Okta in AWS
- AWS Lambda - serverless computing tool that is configured via AWS API to interact with the Okta APIs to fetch relevant details
- Bacon - continuous integration and delivery tool utilized by IDaaS and OIG for software and code development activities such as automated testing and code analysis of source code prior to implementation



- Burp Vulnerability Scanner - Application Vulnerability Scanning Tool used for change deployments as part of the Release Management Process
- Chef - configuration management solution utilized to provision, configure, and manage IDaaS production infrastructure throughout its lifecycle
- Conductor - internal integration tool that allows operators and non-operators to perform and monitor deployments, execute deployment pipelines with various approval steps, and run tasks in any environment
- Crowdstrike - security tool utilized for endpoint detection and response, malware monitoring, and device logging and monitoring
- Hive - ticketing system utilized for centrally managing and tracking security events and incidents flagged within the organization
- GitHub - source code management software utilized to control code versioning and security throughout the code development process
- Jira Software ("Jira") - ticketing system utilized for centrally managing and tracking production issues and change management activities
- JamF Pro - mobile device management tool utilized to manage and secure Mac devices deployed to the organization
- Naruto - internal integration tool that is designed to interact with the Tenable/Nessus API
- PagerDuty - alerting system which delivers alerts to on-call IT personnel when predefined events occur
- Salesforce - used by Okta Support for organization creation, deletion and customer communication. Support.okta.com customer management support portal is also used to help troubleshoot customer issues and requests
- ServiceNow - ticketing system utilized for centrally managing and tracking tickets across internal processes
- Snyk - Static Application Security Testing tool
- Splunk - security information and event management utilized to provide centralized log management
- Tenable (Nessus) - Tenable SC UI is a control plane for Nessus, covering vulnerability scans across applications and network layers
- Terminus - internal tool that is responsible for managing the code deployment protection settings and administration
- VMWare - operational monitoring tool that provides employees with a central, secure hub to access every app, service and system in an organization
- WorkspaceOne - mobile device management tool utilized to manage and secure Windows devices deployed to the organization



- Zabbix - open-source operational monitoring tool used to monitor IT infrastructure and collect and display basic metrics

People

The Company develops, manages, and secures the Systems via separate departments. The responsibilities of these departments are defined in the following table:

People	
Group/Role Name	Function
Executive Management	Responsible for overall security, ensuring enforcement of controls, approving risk assessment, selection, and prioritization of risks to mitigate and provide oversight of the Okta control environment. Management's role is also to help ensure people are trained and systems and processes are in place to meet system uptime, system-wide security, and consistent service execution
Board of Directors	Responsible for overseeing Okta's financial and operational performance and establishing business and strategic objectives to meet the common interests of its shareholders and stakeholders
Technical Operations	Responsible for implementing and operating controls to maintain compliance with relevant security policies and standards for their area of responsibility, initiation of trouble tickets based on operation triggers, second tier response to operation and security incidents, implementation of approved changes, and troubleshooting incidents
Security	Responsible for performing risk assessments, defining control objectives, monitoring performance of security controls, initiation of trouble tickets based on security triggers, first and second tier response to security incidents, operation of security monitoring, measurement, and testing tools
Engineering	Responsible for development of applications, system images, fixes for deployment, second tier response to application issues, and troubleshooting application incidents
Customer Success	Responsible for fielding customer calls regarding customer environments, initiation of trouble tickets based on customer requests, and communicating with customers regarding any scheduled or unscheduled outages or issues through the customer service representatives
Human Resources ("HR")	Responsible for onboarding new personnel, performing background checks, and facilitating the employee termination process



Policies and Standards

Okta management has established controls to help ensure access to the production environment is restricted to those who require access based on role and business justification. Okta has defined various security and operational roles to administer the Okta production resources, which are detailed on Okta's internal wiki. The director of technical operations or higher approves the assignment of production access permissions to the user based upon job responsibilities. Technical operational personnel are responsible for administering and enforcing access rights to the production environment as well as user provisioning and deprovisioning related activities.

Okta maintains a Security Governance Program to help ensure that policies and standards are properly communicated throughout the organization with clear business objectives and requirements outlined and documented. The policies and procedures are defined and maintained, focusing on continual iteration and improvement within the organization.

Okta information security policies and standard operating procedures are documented and available to employees on the team collaboration software, Confluence, for company personnel to review and understand their responsibility for adhering to the associated organizational standards and security requirements. These policies are reviewed by senior management at least annually. In addition, personnel are required to complete security awareness training and annual data privacy training as part of the on-boarding process and each calendar year to help ensure awareness of security policies and procedures. The Okta Information Security Team tracks completion of the annual security awareness training to help ensure employees have completed the training.

Data

Okta allows user access to the following information for the purpose of viewing, and in certain situations, updating or deleting that information. This list may change as services are updated.

- Real name
- Account and user profile information
- User email address
- Username
- User preferences

Customer data stored within the system is considered confidential. As such, this is governed by the confidentiality agreements executed between Okta and customers or vendors. Okta's information classification and handling requirements are defined in the Data Classification and Handling Standard. Users' passwords are hashed and stored securely in Okta's systems. The technical operations group is responsible for managing operational data stored in databases, server logs and data files within the system as well as managing the associated infrastructure and storage.

Asset Lifecycle Management

Okta has an established asset life cycle management service that maintains an inventory of information assets and IT assets, along with necessary and relevant metadata. As a layer of protection, owners are



assigned to each IT and information asset. The service is developed and updated periodically. Okta monitors IT assets to protect against unauthorized access during transit, within and outside of Okta's environment. The Acceptable Use Policy also provides guidance on how IT assets are established and made accessible to personnel. The policy is reviewed and updated on a periodic basis. Authorized users have configurations in place to monitor and control writable, removable media and personally owned, removable media in organization systems. Use of removable media is prohibited in organizational information systems when an identifiable owner on a device cannot be identified. Media handling and disposal procedures are in place to guide authorized personnel in performing sanitization procedures on instances where production data resides to help ensure data and software is unrecoverable prior to retiring the virtual asset.

George Sajonian, george.sajonian@solidigmtechnology.com, 2025-04-07 13:25:44



Relevant Aspects of the Control Environment, Information and Communication, Risk Assessment and Mitigation, Monitoring and Control Activities

The five interrelated components of internal control at the Company include:

- *Control Environment* - The foundation of governance that promotes compliance with policy, standards, management directives, and security objectives. Internal controls influence and govern the procedures and activities of personnel.
- *Information and Communication* - Systems, both automated and manual, that support the identification, capture, and exchange of information in a form and timeframe that enable people to carry out their responsibilities.
- *Risk Assessment* - The entity's identification and analysis of relevant risks to the achievement of its objectives, forming a basis for determining how the risks can be managed.
- *Monitoring* - A process that assesses the quality of internal control performance over time.
- *Control Activities* - The procedural activities that help ensure compliance with management directives, policies, and standards.

Control Environment

The control environment at Okta is a foundation of governance that promotes compliance with policy, standards, management directives, and security objectives. Okta's internal controls influence and govern the procedures and activities of its personnel. The components of the control environment factors include integrity and ethical values, as well as management's commitment to competence; its organizational structure; the assignment of authority and responsibility; and the oversight and direction provided by the board of directors and executive management.

Integrity and Ethical Values

Integrity and ethical values are essential elements of the control environment. Okta's ethical and behavioral standards include management's actions to remove or reduce incentives and temptations that might prompt personnel to engage in dishonest, illegal, or unethical acts. They also include the communication of entity values and behavioral standards to personnel through policy statements and codes of conduct.

Employees are provided with the rules of behavior and the employee handbook, upon hire and annually thereafter, that explains the corporate values and the employee Code of Conduct. Management communicates to employees the value of goodwill with customers and the importance of maintaining this goodwill for future success. In addition, the management team conducts weekly all-hands meetings, providing opportunities to remind personnel of Okta's mission, vision, and values.

Okta takes violations of corporate policy and procedures seriously. To help ensure orderly operations and provide a favorable work environment, management expects employees to follow rules of behavior within the employee Code of Conduct that will protect the interests and safety of employees and Okta. Within reason, management will communicate with respective personnel about remedial actions to



provide consistent expectations of Company policies and standards. The management team is responsible for taking appropriate and timely action to address issues while maintaining anonymous communication channels to allow employees to report any questionable actions to the team without fearing recourse.

Subservice Organization Monitoring

The Third-Party Risk Management Team evaluates the risks associated with the use of AWS and has implemented management oversight and monitoring processes to confirm that the subservice organization continues to provide services in a controlled manner. These include, but are not limited to, the review of third-party service auditor reports and holding discussions with management of the subservice organization. Reviews and monitoring of subservice organizations commensurate with the level of access and risk associated with the service provided.

Additionally, a documented vendor management policy is in place to address the following:

- Process to define scope of services, roles and responsibilities, compliance requirements, and service levels for a potential vendor or business partner
- Classification method based on the assessment of third-party relationships to identify inherent risks
- Due diligence process prior to accepting new vendors or business partners
- Monitoring process to review vendor and business partner compliance on a periodic basis
- Communication protocols to handle incidents and issues
- Termination of contract

Board of Directors

A formal charter and set of bylaws are in place to define the Board of Directors' responsibilities and oversight of management's internal control environment. The Board of Directors is composed of experienced industry veterans. The Chief Executive Officer ("CEO") is one of the common shareholder representatives. External board members attest to independence from management annually to demonstrate their objectivity in evaluations and decision making. Additionally, board members are also evaluated annually to help ensure their skills and expertise are suited to lead senior management and take commensurate action.

The Board of Directors meets at least annually to review and monitor company performance against established goals and metrics. The CEO communicates on an as-needed basis in the event significant issues are required to be raised to the board members. If a significant issue is reported, an internal investigation may be initiated and monitored by the Board of Directors, which may include engagement of an independent third-party investigator, auditor, or outside counsel by the Board of Directors. If key decisions are made by the Board of Directors, they are communicated to Okta by the CEO.

Okta's control awareness is significantly influenced by both its Executive Management and its Board of Directors. Attributes that define Okta's "tone at the top" include the Board of Directors' independence from management, their previous experiences in the Software as a Service ("SaaS") space, their



involvement and scrutiny of operational activities, and the degree to which difficult questions are raised and pursued with management and their interaction with external auditors.

The Audit Committee provides oversight of Okta's corporate accounting and financial reporting processes, financial risk assessment and risk management, systems of internal control over financial reporting and audits of financial statements, systems of disclosure controls and procedures, as well as the quality and integrity of the Company's financial statements and reports. It oversees the selection, engagement terms, fees, qualifications, independence and performance of the registered public accounting firm or firms engaged as Okta's independent outside auditors for the purpose of preparing or issuing an audit report or performing audit and non-audit services. It oversees the scope, activities and performance of the Company's internal audit function, including SOX controls testing and the Enterprise Risk Management program. At least annually, the Audit Committee reviews the company's policies and procedures related to financial issues and adopts any changes, as appropriate; these policies and procedures include the Code of Conduct, Anti-Corruption Policy, Insider Trading Policy and Special Trading Procedures, Audit Committee Complaint Procedures and the ethics reporting system (whistleblower hotline). The Committee's Charter is reviewed annually and proposed changes are recommended to the Board for approval.

The Nominating and Corporate Governance Committee ("NCGC") is appointed by the Board. It recommends criteria for Board and committee membership, establishes a process for identifying and evaluating and recommending Board nominees, and makes director independence recommendations to the Board for approval taking into account Nasdaq Rule 5605(a)(2). It has oversight of any stockholder communications, nominations or proposals received. It reviews and discusses annual corporate succession for the CEO and other executive officers. It develops, recommends and periodically reviews corporate governance guidelines applicable to the Company. It conducts an annual self-performance review and oversees similar reviews for the Board and the other committees. The NCGC Charter is reviewed annually and proposed changes are recommended to the Board for approval. The NCGC meets at least twice a year, and meeting minutes are created and maintained by the Legal Team.

The annual strategic plan, annual budget and significant transactions (such as significant mergers and acquisitions, significant debt transactions and significant leases) are reviewed and approved by the Board of Directors. Okta's strategic plan and budget provide the basis for Okta's business organizations to develop their respective organization's strategic and operational plans; subsequent material changes are also approved. Proposed Vision, Methods, and Targets ("VMTs") that reflect priorities for the upcoming fiscal year are discussed by Okta's leaders at the annual Leadership Summit. VMTs are agreed and finalized by CEO staff. At least annually, a CFO Close meeting is held to review recent quarter financial results and relevant metrics and forecast of future expected performance.

Internal Audit performs an annual Financial Risk Assessment which assesses financial and fraud risks for the Company. The results are agreed with Senior Management and serve as the basis of scope for Sarbanes-Oxley controls testing. Both the assessment and testing results are communicated to the Audit Committee throughout the fiscal year.

In addition, Okta undergoes various reviews by external auditors that include, but are not limited to financial audits by an independent registered public accounting firm and customer quality and



compliance audits covering an extensive range of functional areas such as product development, operations, security, and quality management.

Organizational Structure

Okta's organizational structure provides the framework within which its activities for achieving entity-wide objectives are planned, executed, controlled, and monitored. Establishing a relevant organizational structure includes considering key areas of authority, responsibility, and required lines of reporting. Management structure and team membership within a functional domain is approved by the top-level manager for that domain and recorded in finance and HR records. Following this approval, the managers below communicate and implement changes, as necessary.

Dedicated resources in HR have been assigned the responsibility to support key managers and help ensure they have adequate resources to be successful at Okta. Additionally, a combination of hiring "top tier" employees, focusing on employee success, and having a resource management program, allows Okta personnel to be successful. Within employee offer letters, their reporting relationships are stated along with a statement that they may change over time as business evolves. When new hires are introduced to the team, their general responsibilities and reporting relationships are included as part of the introduction. Organization charts are updated as needed to reflect any changes that are made to reporting relationships and the changes are announced to personnel through the intranet.

Additionally, Okta has implemented the following control activities:

- An Information Security Management Committee ("ISMC") composed of security personnel and executive staff has been established to guide the organization in managing risks. The ISMC meets at least annually to discuss results of risk assessments and status of risk mitigation plans.
- Management formally documents Information Security Management System ("ISMS") security objectives and reviews them annually to align internal control responsibilities, performance measures, and incentives with company business objectives.
- A dedicated Information Security Team has been established to define and enforce security related policies and standards for the Okta platform.
- Management has assigned the responsibility of the maintenance and enforcement of the organization's policies and procedures to the Information Security Officer.
- The Board of Directors reviews internal control performance metrics and the results of third-party assessments provided by management annually.

Accountability

Management defines responsibility and accountability through formal position descriptions that define the skills, responsibilities, and knowledge levels required to perform the job. Policies and practices are in place to guide personnel in hiring, orientation, training, evaluating, counseling, promoting, compensating, and remedial actions. For example, standards for hiring the most qualified individuals, with emphasis on educational background, prior work experience, past accomplishments, and evidence of integrity and ethical behavior, demonstrate Okta's commitment to competent and trustworthy



people. To minimize the risk of malicious behavior and to help ensure that new employees understand the policies for maintaining a secure and safe workplace, potential employees and contractors who have and will have access to confidential data, undergo the following required verifications:

- Background screenings that include examination of criminal conviction records, credit bureau records, social security number ("SSN") verification, as applicable, address history, and verification of previous employment. A background screening commences once an offer of employment has been communicated and accepted. The background screening must be completed and in-hand before an employee's first day of employment.
- Skills assessment for certain engineering positions that are administered online as a screening mechanism for prospective candidates. If the results meet an identified score, those candidates are considered for continued discussion on open requisitions. For other positions, skills assessment is done throughout the interviewing process of activities.
- An electronic acknowledgement indicating new and existing employees have received, read, and agree to adhere to the established guidelines outlined in the employee handbook and the information security policy.

Management conducts semi-annual performance reviews to evaluate employee performance by incorporating alignment to Company values and objectives, individual and team goals, and expected performance. In addition, employees participate in weekly all-hands meetings to understand the alignment of internal control responsibilities, performance measures, and incentives with company business objectives. In the event that a possible violation of procedure or policy is exhibited by an employee, a member of the HR Team will become involved and take a primary role in the investigation of the matter. The appropriate HR representative will document the violation, identify the required parties who will be involved in the investigation, conduct the investigation, communicate the outcome of the investigation with the reporting manager, and follow through on the remedial actions.

Additionally, Okta has implemented the following control activities:

- A formal charter and set of bylaws are in place to define the Board of Directors' responsibilities and oversight of management's internal control environment.
- Organizational charts are in place to communicate the defined key areas of authority, responsibility, and lines of reporting to personnel related to the design, development, maintenance, and monitoring of the system. These charts are communicated to employees and updated as needed.
- An ISMC composed of security personnel and executive staff has been established to guide the organization in managing risks. The ISMC meets at least annually to discuss results of risk assessment and status of risk mitigation plans.
- Management formally documents ISMS security objectives and reviews them annually to align internal control responsibilities, performance measures, and incentives with company business objectives.
- A dedicated Information Security Team has been established to define and enforce security policies and standards for the Okta platform.



- Management has assigned the responsibility of the maintenance and enforcement of Okta's policies and procedures to the Information Security Officer.

Information and Communication

Okta requires information regarding its in-scope systems and operations to carry out internal control responsibilities and support the achievement of its objectives. Management obtains relevant and quality information from internal and external sources, such as monitoring tools in place to report capacity or security issues, third-party assessments on system vulnerabilities, and management assessments of internal and external risks to the control environment. In addition, management has put in place various communication methods - for both employees and external parties such as customers, suppliers, regulators, and shareholders - to help ensure communication occurs in a broader sense, flowing down, across and up the organization. These methods include, but are not limited to, periodic meetings involving management, anonymous reporting channels, and internal collaboration tools.

Internal Communications

Okta has implemented various methods of communication to help ensure that employees understand their individual roles and responsibilities related to processes and controls, and to help ensure that significant events are communicated in a timely manner. These methods include:

- Documented policies and standards are in place to guide personnel on Okta's security requirements. The policies and procedures are communicated to internal personnel via Okta intranet.
- Employees sign an electronic acknowledgement form, upon hire and annually thereafter, indicating they have read and agree to the Code of Conduct.
- Employees sign an electronic acknowledgement form, upon hire and annually thereafter, indicating that they have been given access to the Code of Conduct and information security policy, and understand their responsibility for adhering to the associated organizational standards and security requirements.
- Employees are required to complete security awareness training, upon hire and annually thereafter, to understand their obligations and responsibilities to comply with the corporate and business unit security policies.
- Documented position descriptions are in place to define the skills, responsibilities, and knowledge levels required for particular jobs.
- Executive management holds all-hands meetings on a weekly basis to help ensure Okta's business strategy and initiatives are communicated and understood throughout the organization.
- Employees and vendors are required to sign a confidentiality statement upon hire agreeing not to disclose proprietary or confidential information, including customer information, to unauthorized parties.



- Documented escalation procedures for reporting security incidents are provided to internal users to guide users in identifying, acting upon, and reporting failures, incidents, concerns, and other complaints.
- An ethics hotline and dedicated website are in place for anonymous communication.

External Communications

Okta has also implemented various methods of communications to help ensure that customers understand the role and responsibilities of The Company and to help ensure that significant events are communicated to customers in a timely manner. These methods include:

- Okta's security objectives are communicated to customers via the customer-facing website and the master subscription agreement. This includes any changes to Okta's security and privacy policy, master subscription agreement, and Okta's security and confidentiality commitments to its customers.
- A support site is available to customers that provides system design and operational information, along with troubleshooting documentation.
- Release notes are documented and communicated to customers via the support site for changes that may impact them prior to deployment.
- System alerts, including planned changes to system components, planned outages, and known issues, are communicated to customers via the support site.
- Multiple communication channels are in place to allow contact from customers regarding security incidents, failures, concerns, complaints, and privacy requests, among support mechanisms.
- Signed nondisclosure agreements and/or master service agreements of confidentiality and protection are required before sharing information designated as confidential with third parties.
- Customer administrators are provided with procedures for managing production access and reviewing access logs, upcoming releases, and functionalities.

Customers are responsible for communicating issues by using the ticketing system on the customer portal. Customer requests are recorded and tracked within an internal ticketing system through resolution. The ticketing system is utilized to document, prioritize, escalate, and resolve problems affecting contracted services. Customer requests are managed according to established service-level agreements. Privileged access to customer environments by Okta personnel is granted upon customer requests and access automatically expires within 24 hours.

Risk Assessment and Mitigation

The Security Team maintains a risk-based program to address the dynamic environment in which Okta operates. The team develops approaches to manage security risks identified from multiple sources. The Security Team conducts periodic security assessments to help identify potential risks. Through policy, the Security Team defines and communicates ownership and responsibilities for data integrity,



information classification, and security. The Security Team periodically provides the Board of Directors, the Risk Oversight Committee, and/or the Audit Committee with an overview of cybersecurity risks and steps that management has taken to mitigate such risks.

Okta has established processes to identify and manage risks that could affect their ability to provide reliable cloud services to their customers. These include continually monitoring and evaluating potential risks to the Okta platform through internal and third-party assessments, risk register submissions, an annual internal International Organization for Standardization ("ISO") 27001 review, and change management reviews.

The purpose of this continual risk assessment process is to conduct detailed evaluations of risks that could impact security. This will enable Okta to assess the potential liability, cost, and repercussions of these risks and evaluate the effectiveness and breadth of the current policies, processes, and controls in minimizing or mitigating the identified risks. As part of risk mitigation, Okta implements fixes to identified issues from risk assessments based upon issue likelihood, issue impact, and mitigating controls.

Objective Setting

Okta establishes objectives that promote Company values, improve operational efficiency, or enhance security and compliance posture. Okta has a Risk Management process established to identify potential risks that could impact the Company's ability to meet established objectives. Objective setting enables management to identify measurement criteria for performance and focus on success factors. Okta has established broad categories, including but not limited to the following:

- Strategic objectives – these pertain to the high-level organizational goals and the alignment of those goals to support the overall mission.
- Operations objectives – these pertain to effectiveness and efficiency of the entity's operations, including performance and profitability goals and safeguarding of resources against loss.
- Reporting objectives – these pertain to the preparation of reliable reporting.
- Compliance objectives – these pertain to adherence to laws and regulations to which the entity is subject.

The objective settings enable management to identify measurable criteria for performance and success factors.

Risk Identification and Analysis

Okta understands that identifying significant risks is essential to provide reliable services to its user entities. As a result, in addition to evaluating Okta's interactions with external parties, key members of Okta's executive management and operational teams meet on an as needed basis to identify and review risks to the system.

Documented policies and procedures are in place to guide personnel in identifying risks, assessing changes to the system, and developing risk management strategies as a part of the risk assessment process.



Risk analysis includes identification of key business processes, as well as significant changes to those processes. Once the potential impact and likelihood of risk have been assessed, management considers how the risk should be managed. This involves judgment based on assumptions about the risk, and reasonable analysis of costs associated with reducing the level of risk.

Necessary actions are taken to reduce the potential impact or likelihood of the risk occurring, and identification of the control activities necessary to mitigate the risk. Management has identified these control activities and documented them in the Control Activities section below. Additionally, management reviews the assessed risk levels annually and documents the results.

Risk Factors

Management considers risks that can arise from both external and internal factors, including the following:

- External Factors
 - Technological developments
 - Changing customer needs or expectations
 - Competition that could alter marketing or service activities
 - New legislation and regulation that could force changes in policies and strategies
 - Natural catastrophes that could lead to changes in operations or information systems
 - Economic changes that could have an impact on management decisions
- Internal Factors
 - Significant changes in policies, processes, or personnel
 - Types of fraud, incentives, pressures, and opportunities for employees
 - A disruption in information systems processing
 - The quality of personnel hired, and methods of training utilized
 - Changes in management responsibilities

Potential for Fraud

Management considers the potential for fraud, which can occur in both financial and non-financial reporting, when assessing the risks to Okta's objectives. The absence of controls, or ineffective controls, provides an opportunity for fraud when combined with an incentive to commit fraud. Therefore, documented policies and procedures are in place to guide personnel in identifying the potential for fraud as part of the risk assessment process. Additionally, a risk assessment, including the consideration of fraud risk, is performed annually.

Okta has whistleblower and compliance procedures within the Code of Conduct that allows individuals to anonymously submit complaints to the Company. A whistleblower hotline is established and is accessible to both employees within the Company and external individuals. All reported matters are routed to the Chief Legal Officer, Chief Compliance Officer, and Vice President of Internal Audit with



details of the claim. Each matter is investigated, discussed, and presented to the Audit Committee, where appropriate.

Internal Audit

Internal Audit is independent of management and the Head of Internal Audit reports directly to the Chair of the Audit Committee. Personnel executing activities have the requisite level of experience and credentials to evaluate the company's internal control environment. The Internal Audit function assesses risks, evaluates the effectiveness of internal controls, and regularly communicates results to the business, management, and the Audit Committee based on the Institute of Internal Auditors professional standards. Issues identified by both internal and external auditors are tracked and monitored to ensure timely remediation of issues and implementation of controls. Issues are periodically reported to both management and the Audit and Risk Committee.

Risk Mitigation

Risk mitigation activities include the ability to identify, select, and develop activities that sufficiently manage the identified risks within organizational risk tolerances. Management has documented policies and procedures to guide personnel in periodic risk assessments to address risks arising from potential business disruptions and development of risk mitigation strategies. Assigned risk owners select and develop control activities to mitigate the risks identified during the annual risk assessment process. The control activities are documented within the risk mitigation plans created by the risk owners for risks above the tolerable threshold.

Third-Party Risk Management

Okta has a formal framework for managing the lifecycle of third-party subservice organizations and vendor relationships, including how Okta assesses, manages, and monitors its suppliers to help ensure an appropriate control environment is consistent with Okta's security, availability, and confidentiality commitments.

The Third-Party Risk Management Team evaluates the risk associated with the use of third-party subservice organizations, vendors, and suppliers, and has implemented management oversight and monitoring processes to confirm that these third parties continue to provide services in a controlled manner. These include, but are not limited to, the review of attestation and compliance reports and certifications, and holding discussions with management of the third parties. Reviews and monitoring of these third parties commensurate with the level of access and risk associated with the service provided.

To mitigate risks introduced by third parties, management performs due diligence procedures prior to onboarding a vendor or business partner. For vendors that are critical to the business operations, management reviews independent service auditor's reports and compliance reports (i.e., System and Organization Controls [SOC] report) at least annually to help ensure third-party service providers are in compliance with management's objectives. The review also evaluates the results included within the attestation and compliance reports to determine if controls are sufficient to achieve Okta's principal service commitments and system requirements. Any deviations are assessed to determine the potential impact to Okta's control environment.



Vendor agreements such as the terms of service and master subscription agreements, including any security, availability, and confidentiality related commitments, are also reviewed and signed prior to engaging with any third parties. Additionally, employees and vendors are required to sign a confidentiality statement upon hire agreeing not to disclose proprietary or confidential information, including customer information, to unauthorized parties.

Monitoring

Okta management performs continuous monitoring activities to assess the quality of internal control over time. It involves assessing the design and operation of controls and taking necessary corrective actions. Monitoring activities are used to initiate corrective action through department meetings and informal notifications. Management is responsible for directing and controlling operations and for establishing, communicating, monitoring control activities and procedures. Monitoring activities include using information from communications from external parties such as user entity complaints and regulatory comments that may indicate problems or highlight areas in need of improvement. Management has implemented a self-assessment and compliance program to help ensure the controls are consistently applied as designed.

Ongoing Monitoring

Okta has implemented the following controls for ongoing monitoring activities:

- The control environment and its control effectiveness are evaluated on an ongoing basis. The Chief Security Officer ("CSO") is assigned the responsibility for maintenance and monitoring of ongoing security activities.
- Okta manages boundary protection device interfaces (e.g., gateways, firewalls, routers, guards, encrypted tunnels) to secure and restrict connections to external or untrusted networks or systems, in alignment with enterprise architecture.
- Monitoring tools are used to continuously monitor security events, latency, packet loss, hops, network performance, and virtual server performance. Okta maintains network integrity software and has documented network management policies. Documented escalation procedures are in place to initiate corrective actions to unfavorable network performance.
- Access logs for production systems are continuously monitored for evidence of suspicious activity or unauthorized access. The Technical Operations Team reviews flow-based network monitoring to detect unusual patterns of network activity.
- Capacity monitoring is performed to help ensure that utilization of resources is within acceptable limits and below maximum utilization for a resource. Evaluating and establishing that additional capacity is available for resources helps to ensure that growth can be accommodated quickly, and that user experience will not be degraded.
- Okta performs performance testing when developing new software releases to evaluate the performance of new releases prior to migration into the production environment.
- Okta has also implemented a security program that provides required logical, and operational controls that operate specifically on the Okta cloud environment, while simultaneously



leveraging services within the Okta corporate control environment to provide a control environment over personnel security and governance.

Separate Evaluations

Evaluation of the internal control system may be prompted by major strategy or management change, major acquisitions or dispositions, or significant changes in operations or methods of processing information. Evaluations of internal control vary in scope and frequency, depending on the significance of risks being controlled and importance of the controls in reducing the risks. Controls addressing higher-priority risks and those most essential to reducing a given risk will tend to be evaluated more often.

Often, evaluations take the form of self-assessments, where persons responsible for a particular unit or function will determine the effectiveness of controls for their activities. These assessments are considered by management, along with any other internal control evaluations. The findings of these efforts are utilized to help ensure follow-up actions are taken and subsequent evaluations are modified as necessary.

Deficiencies in management's internal control system surface from many sources, including Okta's ongoing monitoring procedures, separate evaluations of the internal control system and external auditing parties. Management has developed protocols to help ensure findings of internal control deficiencies are reported to personnel responsible for the function or activity involved, the Security Team, and applicable management personnel. Management tracks related deficiencies on an ongoing basis. This process enables management to provide needed support or oversight for taking corrective action, and to communicate with others in the organization whose activities may be affected.

Additionally, the Board of Directors review internal control performance metrics and the results of third-party assessments provided by management annually.

System Monitoring

Okta monitors daily business and operational activities, including the internal control environment. Okta has implemented a set of network and application tools for monitoring the production environment and production support system:

Security Groups

AWS security groups are in place to provide security for the production environment maintained within AWS. The security groups monitor incoming network traffic by analyzing the data packets and determine whether they should be allowed through based on the ruleset. Okta is responsible for the initial configuration and maintenance of the ruleset. Administrative access privileges to manage the security groups are restricted to authorized technical operations personnel. In the event that a security group needs to be added or modified, technical operations will document the change and utilize a ticketing system to track the change, including approval through resolution. Additionally, AWS security group changes are logged by a centralized logging tool and automated alerts are sent to IT security personnel for review and remedial action.

Okta participates in special interest groups, security associations, and security forums to obtain insights about security programs, security risk and threat landscape, system security and vulnerability



alerts, advisories, and directives. Okta shares information from alerts, advisories, and directives within the organization. Appropriate actions are taken in response to information system security alerts and advisories.

Event Logging

Splunk, a SaaS-based log collector and parsing service, is used across the Okta environment to monitor anomalous system conditions, and for forensic analysis after an incident. Logs for production systems are forwarded to Splunk for continuous monitoring of suspicious activity or unauthorized access. Alerts are set to send messages to the Operations Team if predefined thresholds are exceeded so the Operations Team can proactively respond to any system errors or anomalies.



Description of Control Activities and Relevant Aspects of Operations

Access Management

Okta implements access controls across its network, infrastructure, and services to restrict user access to only authorized and appropriate users, while preserving data security, availability, and confidentiality.

Access Authentication and Authorization

Access to system information, including confidential information, is protected by multiple authentication and authorization mechanisms.

Okta uses an instance of its own IDaaS solution to manage access to corporate resources. Each user is assigned a unique user account, password, and a second-factor authentication via Okta Verify to provide multi-factor authentication. The IT Team is responsible for managing access rights within the Okta organization and administrative access is restricted to authorized IT personnel.

To access the production environments from the front-end via the AWS console, users authenticate to the AWS console via multi-factor authentication.

To access the production environment from the back end, multiple authentication and authorization mechanisms are utilized, as mentioned in the following sections.

Remote Access and Production Environment Access

Remote access to the IDaaS production resources is restricted through an encrypted Virtual Protocol Network ("VPN") to help ensure the integrity of data passing through the public network. VPN connections are secured utilizing AES-128-bit or greater encryption. Users are authenticated with an Okta-issued user specific public key infrastructure ("PKI") certificate before establishing a VPN session. Administrative access to the VPN system is restricted to authorized personnel. In the event that an employee is terminated, IT personnel revoke the associated VPN certificate as a component of the termination process.

The production environment is administered remotely, and access must be performed through a secure VPN connection or through an internal implementation of the Advanced Server Access ("ASA") application, as well as a hardware multi-factor device.

Access to the production environment via a VPN connection requires an Okta-issued user specific PKI certificate to be installed on the user's personal computer ("PC") and a hardware multi-factor device. Once connected to the production VPN, the user authenticates to the production server over Secure Shell Protocol ("SSH") encryption protocol using uniquely assigned SSH key-pair in which the private key is enabled only with the technical operations user's unique username and password.

Access to production resources is controlled using permissions associated with Okta technical operations staff and strictly controlled system accounts and is limited to only what is required for users and services to undertake their duties. After a user account and public-private keys have been generated, the accounts, including the groups the individual belongs to, are propagated to the production IDaaS servers using Chef, a configuration management tool. Chef is used to help ensure



that IDaaS servers have a consistent configuration and access rights are up to date. Management has restricted ability to create accounts in the production environment as well as administrative access privileges within the production environment to authorized technical operations personnel.

Access Requests and Access Revocation

A formal process has been established for managing user accounts and controlling access to Okta's resources. IT personnel are responsible for assigning and maintaining access rights to the corporate systems based on the individual's job role and department. Management requires access requests to be formally documented to help ensure the required activities are completed. Access to the production environment is managed by the Technical Operations Team. Upon notification of an employee termination, an HR Workforce Administration Case is logged in ServiceNow, which is assigned to People Ops and tracked until the ticket is closed and access has been removed.

Access is deprovisioned promptly when a user is terminated on the termination date. Once a user is terminated at the network level, they no longer have access to the production environment, VPN or MFA.

User access reviews are performed at least once every 6 months. Modifications or removal of privileges is performed as necessary. An up-to-date record of the users or profiles of users who have authorized access to the information system is maintained.

As a tracking mechanism, Okta has a centralized system log that captures a comprehensive set of activity events including user import, application assignment, account activation and deactivation, Okta integrated application login actions, and Okta login actions. The data is captured in real time and maintained historically to support both interactive troubleshooting and detailed reporting. Such data is available to customers through the administrative portal in an industry-standard format over a secure connection (i.e., CSV or REST API).

Change Management

Okta utilizes the agile software development methodology for application and API development. Program change documents and security best practices including policies, procedures, and guidance documents are documented on the Okta wiki. Okta analyzes changes to the information system to determine potential system impacts prior to change implementation and immediately after implementation. Services that are new or changing are implemented in accordance with the defined service management objectives and requirements. Security and privacy requirements are taken into account while allocating resources for new information system development efforts or changes to existing information systems and applications.

Change Development and Releases

Planned releases are performed on a weekly sprint schedule with releases first deployed to a "preview" (sandbox) environment. Production changes are documented and tracked in a ticketing system. Separate development, test, and production environments are maintained. Administrative and technical controls require that changes are tested in lower environments prior to production implementation. Production data is not utilized for change development and testing efforts, and



likewise, test data is not used or migrated to production. Additionally, incidents requiring a change to the system follow the standard change management process.

The production change request process enforces and records request authorization, code review, testing, migration approval, potential impacts, rollback steps, and implementation guidance. A continuous integration application is utilized to automate the release management process, which includes building, testing, tagging releases, and assigning versions. Version control software is utilized to restrict access to application source code and provide rollback capabilities. Validation checks are incorporated within applications to ensure accurate processing of information. The validation process involves verifying the input and output of programs and applications within the information system. In case of errors, appropriate error messages are generated, containing the necessary details for authorized personnel to take corrective actions. These error messages are designed to provide the required information without disclosing any data that could potentially be exploited by adversaries. Approval for releases is obtained from the required business unit manager prior to moving the changes to production. Approved changes are performed or managed directly by authorized technical operations personnel; separation of duties between change developers and change implementers exists in the production environment. Emergency changes undergo a variety of testing ranging from peer testing to automated testing prior to the release into production and approvals may occur after the fact based on the severity of the issue being addressed. Okta limits privileges wherein developers do not have access to migrate changes to the production environment.

Configuration Management

A configuration management tool is utilized to manage and maintain the IDaaS production servers and to mitigate the risk of unauthorized changes. The configuration management tool is also established to help ensure that baseline configurations for all assets are established to address security vulnerabilities.

The configuration management process helps ensure that information assets are hardened and periodically reviewed and are aligned with security best practices. Okta's endpoint configurations for workstations and mobile devices are mandatory. Configuration baselines must be approved and installed on all workstations, and mobile devices require multi-factor authentication along with device encryption, and Mobile Device Management ("MDM") enabled to access the internal network. Okta also installs security tools such as antivirus and malware detection and malicious code protection on all Okta managed endpoint devices and systems. Malware protection is installed, updated, enabled and monitored regularly. Installation of software by users is controlled and monitored to avoid employees from installing vulnerable software on Okta's assets.

Production Code Scanning

Okta utilizes Snyk to regularly scan the code base on the master branch of repositories to detect vulnerable open-source libraries being used. The scanners are integrated and are run automatically to scan any changes made to the code base within the repositories. Every identified vulnerability from the scan is logged in the ticketing system and triaged by the Vulnerability Management Team based on the severity of the vulnerability.



Separation of Environment

Okta's multitenant architecture is designed to logically separate Customer Data based on business needs, as instructed by the customer.

Customer Data Deletion

Okta maintains policies and procedures regarding the deletion of Customer Data so that the data cannot be read or reconstructed. Customer Data is deleted using secure deletion methods.

Okta Reports

Okta reports are covered in Okta's change development and release process. This includes, but is not limited to, testing in a lower environment prior to production, version control, validation checks, and approvals for releases.

Disaster Recovery and Backup Strategy

Business Continuity Plan and Disaster Recovery Plan

Business Impact Analysis ("BIA") is performed to understand enterprise resilience requirements and determine recovery objectives. BIA takes into consideration the criticality of the organizational processes and services and their components, including associated applications and systems.

A business continuity plan that includes an impact assessment of critical assets, services, and functions, is maintained, documented, and periodically reviewed. The business continuity plan is used in the event of a crisis, disruption, or failure. Okta periodically tests the business continuity plan to verify the effectiveness of the plan, taking into consideration key metrics such as recovery point objectives and recovery time objectives. Where issues are noted, remediation plans are taken to meet Okta's requirements.

Disaster and functional recovery plans are documented, communicated, and periodically updated to reflect actionable plans to recover from a disaster. Disaster and functional recovery plans are put into action after an identified crisis, failure, or disruption. Okta tests the plans annually to help ensure effectiveness of the disaster and functional recovery plan. After the disaster recovery tests are performed, outputs of the tests are captured, analyzed, and discussed to determine the scope of the next steps for continuous improvement of the tests. The improvement efforts are documented. If any issues are noted, Okta takes corrective actions to meet the organization's requirements.

Backup and Restoration

Automated systems are in place to manage recurring processes such as production jobs and data backups.

Okta utilizes regular database snapshots recorded to Amazon Simple Storage Service ("S3") for production backup data. Data stored within AWS S3 includes cross-region replication, which automatically replicates the data across separate AWS regions. For IDaaS, Okta's system monitoring tools are configured to automatically alert the Operations Team if replication lag time falls significantly behind production databases.



Backup restoration testing is conducted at least annually to validate that critical systems and production backup data can be recovered.

Multiple Availability Zones

Amazon services are hosted in multiple locations worldwide. These locations are composed of region, availability zones ("AZs"), and local zones. The region is a separate geographic area and has multiple, isolated locations, known as AZs; each AZs has multiple data centers.

The Okta platform is configured to reside in multiple availability zones within multiple regions. Data is replicated to multiple databases on separate availability zones on separate servers within AWS. In the event one zone is unavailable, complete copies of the solution are available in other AWS zones.

Vulnerability Management

Vulnerability Management practices are in place to identify, evaluate, prevent, and report on security vulnerabilities that are likely to be used by malicious attackers to compromise an application, device and/or network. Security reviews and vulnerability assessments are performed by information security personnel and third-party vendors on a periodic basis to identify threats and assess their potential impact to system security, the production network, and the web application. Security vulnerabilities that are detected are triaged and monitored through resolution. If a potential or actual security breach is encountered, security personnel work to identify the cause and remediate the breach immediately.

For the IDaaS product, Okta's Vulnerability Management Team currently utilizes the Tenable Nessus tool to scan for vulnerabilities at various frequencies. The Nessus control plane provides API control to Tenable Nessus scanners on IDaaS production accounts in AWS.

Penetration testing is performed by information security personnel and third-party vendors on an annual basis or after any significant update or modification to the infrastructure, to identify threats and assess their potential impact on production systems. Based on the results of the penetration test, remediation plans are developed to address risks. The penetration tests are designed to be aligned with industry standards covering the application and network layer.

Patch Management

Information security and technical operations personnel monitor for recommended required patches and upgrades on an ongoing basis to mitigate damage to Okta operations resulting from exploitation of published vulnerabilities. The vulnerabilities are identified by reviewing security notifications from authorized technology or third-party resources, testing internal and external networks, and reviewing security issues reported by external users including customers. If a patch is deemed necessary to mitigate the detected vulnerability, information security and technical operations personnel will utilize a ticketing system to manage and track the patch installation until resolution. Management has restricted the ability to apply patches to authorized personnel.

Ongoing workstation asset management, security patch deployment, password protection, and media drive protection, are monitored using policies deployed through the asset management software to enable drive encryption, enforce automated patch updates, and prevent the use of removable media.



Encryption

Okta's Encryption Management Standard outlines the controls and techniques used to encrypt data aligned with relevant agreements, legislations, and regulations. To protect data while in transit, customer sessions to Okta web servers are transmitted utilizing Hypertext Transfer Protocol Secure ("HTTPS") and Transport Layer Security ("TLS") encryption protocols and allow for 2048-bit encryption. Okta utilizes a trusted certificate authority ("CA") to issue a TLS digital certificate to inform users that the Okta website is secure. Okta utilizes Advanced Encryption Standard ("AES") volume encryption to protect organizationally classified data at rest and encrypts sensitive customer data in the database using AES 256-bit encryption. Okta applies an AWS key management service to manage encryption keys used to encrypt data.

Incident Response

Incident response and escalation procedures are in place to manage unexpected incidents impacting the business. The incident response process defines activities for identifying and mitigating security breaches and managing communications with Okta personnel and customers. The actions taken to resolve and contain the incidents are documented in an incident management system. When an issue is detected, the Technical Operations Team will examine and attempt to triage the issue and escalate the issue as needed.

Okta utilizes online collaboration tools and e-mail for communicating and resolving any identified incidents. The Information Security Team is responsible for the identification, resolution, and communication of security related incidents to potentially impacted parties. Customers are responsible for reviewing incident and service level reports provided by Okta, where applicable, and reporting any issues based on terms of the service agreement. To help reduce the prospect of repeat incidents, Okta reviews past incidents and identifies lessons learned. The established post-mortem process allows Okta to modify and improve the security incident response and management process as needed.



Criteria and Related Controls

The Company has specified the criteria and identified the controls that are designed to achieve the related criteria. The specified criteria and related controls are presented in Section 4, "Section 4, "Okta's Controls, Trust Service Criteria, Service Auditor's Test of Controls, and Test Results" and are an integral component of the Company's description of the System.

User Entity Responsibilities ("UER")

The Company's controls related to the Systems cover only a portion of overall internal control for each user entity of the Systems. It is not feasible for the criteria related to the Systems to be achieved solely by the Company. Therefore, each user entity's internal control should be evaluated in conjunction with the Company's controls described in Section 4 of this report, considering the related UERs identified for the specific criteria. For user entities to rely on the controls reported herein, each user entity must evaluate its own internal controls to determine whether the identified UERs have been implemented and are operating effectively, and to provide additional assurance that the applicable trust criteria described within this report are met.

The UERs presented do not represent a comprehensive list of all controls that should be employed by user entities, but rather, a summary of necessary controls to meet the trust service criteria. Management of user entities should assess their own control environments to see whether the controls are implemented and operating effectively, and is responsible for the following:

Related Criteria	User Entity Responsibilities
CC2.3	User entities are responsible for staying informed of new features and functionality by reviewing Okta's updates and release notes.
CC2.3	User entities are responsible for updating any internal controls or processes, which may be impacted by the feature change or new functionality.
CC2.3	User entities are responsible for the security and confidentiality of the information submitted on Okta's support tickets.
CC6.1, CC6.2, CC6.3	User entities are responsible for maintaining appropriate policies and procedures supporting the appropriate use and access services provided by Okta.
CC6.1	User entities are responsible for managing access configurations within the Okta services. This includes securely implementing and maintaining effective internal controls over any single sign-on solution if used in conjunction with Okta's service with appropriate user IDs and passwords that are used to access services provided by Okta.
CC6.2, CC6.3	User entities are responsible for approving and provisioning access to their Okta instances.



Related Criteria	User Entity Responsibilities
CC6.2, CC6.3	User entities are responsible for disabling a User's ID and credentials immediately upon a user's termination and ends any active sessions for the user.
CC6.2, CC6.3	User entities are responsible for reviewing security access on a periodic basis and monitor all user access.
CC6.1, CC6.2, CC6.3	User entities are responsible for requesting, approving, and monitoring Okta's customer support access to their accounts.
CC6.4	User entities are responsible for ensuring physical security and environmental controls are in place to protect their machines, including remote employees or at-home agents for which the user entity allows connectivity, to access Okta's services.
CC7.1, CC7.2	User entities are responsible for communicating any bugs, vulnerabilities, or processing issues discovered to Okta.
C1.1	User entities are responsible for establishing and maintaining appropriate policies and procedures supporting the appropriate use of Okta's services, including how employees and users are handling their information or data that is being used and stored, and how they are maintaining data used in their testing environment.
C1.1, C1.2	User entities are responsible for requesting data deletion in line with their requirements.
A1.2, A1.3	User entities are responsible for creating backups of their data.



Subservice Organization and Complementary Subservice Organization Controls (CSOCs)

The Company uses AWS as a subservice organization to provide physical safeguards, environmental safeguards, infrastructure support and management, and storage services. The Company's controls related to the Systems cover only a portion of the overall internal control for each user entity of the System. The description does not extend to the colocation services for IT infrastructure provided by the subservice organization. Section 4 of this report and the description of the system only cover the criteria and related controls of the Company and exclude the related controls of AWS.

Although the subservice organization has been carved out for the purposes of this report, certain criteria are intended to be met by controls at the subservice organization. CSOCs are expected to be in place at AWS related to physical security and environmental protection as well as backup. The subservice organization's physical security controls should mitigate the risk of unauthorized access to the hosting facilities. AWS's environmental protection controls should mitigate the risk of fires, power loss, climate, and temperature variabilities.

Okta's management receives and reviews the AWS SOC 2 report annually. In addition, through its operational activities, Okta's management monitors the services performed by AWS to determine whether operations and controls expected to be implemented are functioning effectively. Management communicates with the subservice organization to monitor compliance with the service agreement, stay informed of changes planned at the hosting facility, and relay any issues or concerns to AWS management.

It is not feasible for the criteria related to the System to be achieved solely by the Company. Therefore, each user entity's internal control must be evaluated in conjunction with the Company's controls and related tests and results described in Section 4 of this report, taking into account the related CSOCs expected to be implemented at AWS as described below.

Criteria	Complementary Subservice Organization Controls
CC6.1 CC6.7	AWS is responsible for encrypting databases in its control.
CC6.5	AWS is responsible for securely decommissioning and physically destroying production assets in its control.
CC6.4	AWS is responsible for restricting data center access to authorized personnel. AWS is responsible for the 24/7 monitoring of data centers by closed circuit cameras and security personnel.
A1.2	AWS is responsible for the installation of fire suppression and detection and environmental monitoring systems at the data centers. AWS is responsible for protecting data centers against a disruption in power supply to the processing environment by an uninterruptible power supply ("UPS").



Criteria	Complementary Subservice Organization Controls
	AWS is responsible for overseeing the regular maintenance of environmental protections at data centers. AWS is responsible for data backup, monitoring of backup failures, and initiating corrective action when failures occur. AWS is responsible for monitoring the backup and replication of AWS system components across multiple Availability Zones.

Section 4: Okta's Controls, Trust Service Criteria, Service Auditor's Test of Controls, and Test Results

George Sajonian, george.sajonian@soliditytechnology.com, 2025-04-07T15:45:12.402Z



Okta's Controls, Trust Service Criteria, Service Auditor's Test of Controls, and Test Results

Criteria and Controls

On the pages that follow, the applicable trust services criteria and the controls to meet the criteria have been specified by, and are the responsibility of, Okta.

Procedures for Assessing Completeness and Accuracy of Information Provided by the Entity (IPE)

For controls requiring the use of IPE, including Electronic Audit Evidence (EAE) (e.g., controls requiring system-generated populations for sample-based testing), we performed a combination of the following procedures where possible based on the nature of the IPE to address the completeness, accuracy, and data integrity of the data or reports used: (1) inspected the source of the IPE, (2) inspected the query, script, or parameters used to generate the IPE, (3) agreed data between the IPE and the source, and/or (4) inspected the IPE for anomalous gaps in sequence or timing to determine the data is complete, accurate, and maintains its integrity. In addition to the above procedures, for controls requiring management's use of IPE in the execution of the controls (e.g., periodic reviews of user access listings), we inspected management's procedures to assess the validity of the IPE source and the completeness, accuracy, and integrity of the data or report.



Okta's Controls, Service Auditor's Tests of Controls, and Test Results

Entity Level Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
ELC-01-02	The Company has whistleblower and compliance procedures within the Code of Conduct and Audit Committee complaint procedures that allow individuals to anonymously (to the extent permitted by applicable law) submit complaints to the Company. The Company uses a third-party service provider to manage the company's ethics reporting system (i.e., a whistleblower hotline). All complaints are routed via automated email notification to the Chief Legal Officer, Chief Compliance Officer, and Head of Internal Audit. Complaints relating to accounting, internal accounting controls or auditing matters, potential violations of anti-corruption laws and potential violations of the U.S. federal securities laws are routed via automated email notification to the Chair of the Audit Committee. Each matter is investigated, discussed, and presented to the Audit Committee, where appropriate. If a complaint involves the Chief Legal Officer, it is routed to the CFO.	<u>CC.2.2</u> <u>CC.2.3</u>	Inquired of the control owner and ascertained that a whistleblower hotline was available for employees to anonymously report possible violations of conduct. Further inquired that each reported matter was investigated, discussed, and presented to the Audit Committee, where appropriate.	No deviations noted.
			Inspected the Okta Code of Conduct and Audit Committee Charter and ascertained that whistleblower and complaint procedures were available for employees to anonymously submit complaints to the Company.	No deviations noted.
			Inspected the whistleblower hotline tool and ascertained it maintained a repository of employee complaints raised and was configured to route automated email notification to the Chief Legal Officer, Chief Compliance Officer, and/or Head of Internal Audit.	No deviations noted.
ELC-02-01	Annually, all Board of Directors and Company Executive Officers are required to submit a Directors and Officers (D&O) questionnaire, in which related party interests and transactions must be disclosed. At least annually, the list of	<u>CC.1.2</u> <u>CC.1.4</u> <u>CC.2.2</u> <u>CC.2.3</u>	Inquired of the control owner and ascertained that the Directors and Officers ("D&O") questionnaire was required for all Board of Directors and Company's Executive Officers in financial reporting oversight role based on defined timing.	No deviations noted.



Entity Level Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
	related parties is updated by all directors and executive officers.		Inspected the Directors and Officers ("D&O") questionnaire and ascertained that the members completed the questionnaire and the related party interests and transactions were disclosed annually.	No deviations noted.
			Inspected the Related Party Analysis file and ascertained that related parties were reported, updated, and reviewed for disclosure at least annually.	No deviations noted.
ELC-02-02	The Board of Directors (BOD) monitors and evaluates the operational and financial performance of the Company. Minutes of Board meetings are created and maintained by the Legal Team. Additionally, the CFO may send the BOD periodic updates on Company financial performance as he deems appropriate, based on circumstances and timing.	<u>CC.1.2</u> <u>CC.1.4</u> <u>CC.2.2</u> <u>CC.2.3</u> <u>CC.3.1</u> <u>CC.3.4</u>	Inquired of the control owner and ascertained that the operational and financial performance of the Company was monitored and evaluated by the Board of Directors ("BODs") at least quarterly.	No deviations noted.
			Inspected the documented meeting minutes for the Board meeting for a sample of quarters and ascertained that the BODs monitored and evaluated the operational and financial performance of the Company quarterly.	No deviations noted.
ELC-02-03	The 'NCGC' is appointed by the Board. It recommends criteria for Board and committee membership, establishes a process for identifying and evaluating and recommending Board nominees, and makes director independence recommendations to the Board for approval. It has oversight of any stockholder communications, nominations or proposals received. It reviews and discusses annual corporate succession for the CEO and other executive officers. It develops, recommends and periodically reviews and updates	<u>CC.1.2</u> <u>CC.1.4</u> <u>CC.2.2</u> <u>CC.2.3</u>	Inquired of the control owner and ascertained that the Board had appointed the Nominating and Corporate Governance Committee ("NCGC") as an oversight function. Further inquired that the NCGC Charter was reviewed annually, the committee conducted an annual self-review, met at least twice a year, and meeting minutes were created and maintained by the Legal Team.	No deviations noted.
			Inspected the Committee's Charter and ascertained that it was reviewed annually and proposed changes were recommended to the Board for approval.	No deviations noted.



Entity Level Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
	corporate governance guidelines applicable to the Company. It conducts an annual self-performance review and oversees similar reviews for the Board and the other committees. The NCGC Charter is reviewed annually, and proposed changes are recommended to the Board for approval. The NCGC meets at least twice a year, and meeting minutes are created and maintained by the Legal Team.		Inspected the Committee's Charter and Proxy Statement and ascertained that the following were the responsibilities of the committee: • Recommends criteria for Board and committee membership • Establishes process for identifying and evaluating and recommending Board nominees • Makes director independence recommendations to the Board • Provides oversight of any stockholder communications, nominations or proposals • Reviews and discusses annually corporate succession for the CEO and other executive officers • Develops, recommends and periodically reviews for update corporate governance guidelines • Conducts an annual self-performance review	No deviations noted.
			Inspected the board meeting minutes and ascertained that the committee met at least twice a year to discuss matters related to their oversight responsibilities including the appointment by the Board of the "NCGC".	No deviations noted.
ELC-02-04	The Audit Committee provides oversight of the Company's corporate accounting and financial reporting processes, financial risk assessment and risk management, systems of internal control over financial reporting and audits of financial statements, systems of disclosure controls and	<u>CC.1.2</u> <u>CC.1.4</u> <u>CC.2.3</u> <u>CC.4.1</u> <u>CC.4.2</u>	Inquired of the Control Owner and ascertained that the Audit Committee provided oversight for the Company while maintaining independence and financial literacy requirements. Further inquired that the Company's policies, procedures, and charter, were reviewed by the Audit Committee at least annually.	No deviations noted.



Entity Level Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
	procedures, as well as the quality and integrity of the Company's financial statements and reports. It oversees the selection, engagement terms, fees, qualifications, independence and performance of the registered public accounting firm or firms engaged as the Company's independent outside auditors for the purpose of preparing or issuing an audit report or performing audit and non-audit services. It oversees the scope, activities and performance of the Company's internal audit function, including SOX controls testing and the Enterprise Risk Management program. All Committee members satisfy the independence and financial literacy requirements set forth by the SEC, and at least one Audit Committee member meets the definition of "financial expert". At least annually, the Audit Committee reviews the company's policies and procedures related to financial issues and adopts any changes, as appropriate; these policies and procedures include the Code of Conduct, Anti-Corruption Policy, Insider Trading Policy and Special Trading Procedures, Audit Committee Complaint Procedures and the ethics reporting system (whistleblower hotline). The Committee's Charter is reviewed annually and proposed changes are recommended to the Board for approval.		Inspected the Committee Charter and Proxy Statement and ascertained that the Audit Committee provided oversight of the Company's corporate accounting and financial reporting processes, financial risk assessment and risk management, systems of internal control over financial reporting and audits of financial statements, systems of disclosure controls and procedures, as well as the quality and integrity of the Company's financial statements and reports.	No deviations noted.
			Inspected the Committee Charter and Proxy Statement and ascertained that the Audit Committee reviewed the public accounting firm or firms engaged as the Company's independent outside auditors, as well as the performance of the internal audit function and other activities undertaken by them.	No deviations noted.
			Inspected the Proxy Statement and ascertained that Okta has confirmed that the requirements for independence, financial literacy, and financial expertise have been met.	No deviations noted.
			Inspected the Committee's Charter and ascertained that it was reviewed annually and proposed changes were recommended to the Board for approval.	No deviations noted.
			Inspected the Audit Committee meeting minutes and ascertained that the review of the policies and procedures were performed at least annually.	No deviations noted.
ELC-03-01	The annual strategic plan, annual budget and significant transactions (such as significant	CC.1.2 CC.1.4	Inquired of the control owner and ascertained that the annual strategic plan, annual budget, and significant	No deviations noted.



Entity Level Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
	mergers and acquisitions, significant debt transactions and significant leases) are reviewed and approved by the Board of Directors. Approved in December, the Company strategic plan and budget provide the basis for Okta's business organizations to develop their respective organization's strategic and operational plans; subsequent material changes by Management are also approved.	CC.2.2 CC.2.3 CC.3.1	transactions were reviewed and approved by the Board. Inspected the documentation of the strategic plan, applicable budget, and significant transactions, and ascertained that the strategic plan, annual budget, and significant transactions were approved by the Board.	No deviations noted.
ELC-07-01	Proposed vision, methods, and targets (VMTs) that reflect priorities for the upcoming fiscal year are discussed by Company leaders at the annual Leadership Summit. VMTs are agreed and finalized by CEO staff in December. Annual budgets are developed in line with the agreed VMTs; they are presented in December and finalized in January by CEO staff. Quarterly, a CFO Close meeting is held to review recent quarter financial results and relevant metrics and forecast of future expected performance.	CC.1.5 CC.4.2	Inquired of the control owner and ascertained that Okta had a framework to establish annual vision, methods, and targets ("VMTs") that reflected company priorities. Further inquired that the VMTs were reviewed periodically and that the CFO close meeting was held to review recent quarter financial results, relevant metrics, and forecast of future expected performance.	No deviations noted.
			Inspected the documentation of the proposed vision, methods, and targets and ascertained that it had been established for the fiscal year and that the annual budget was developed in line with the VMTs.	No deviations noted.
			Inspected the CFO close meeting deck for a sample of quarters, and ascertained that the financial results, relevant metrics, forecast of future expected performance, and progression against target were reviewed and discussed quarterly.	No deviations noted.
ELC-07-02	Annually, Internal Audit performs a Financial Risk Assessment, which considers financial risks for	CC.3.1 CC.3.3	Inquired of the control owner and ascertained that the Okta Internal Audit Team performed an annual	No deviations noted.



Entity Level Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
	the Company. Fraud risks are also considered and assessed. The results are agreed with Senior Management and serve as the basis of scope for Sarbanes-Oxley controls testing. Both the assessment and testing results are communicated to the Audit Committee throughout the fiscal year.		Financial Risk Assessment for the purpose of evaluating financial risks for the company, including fraud risks. Further inquired that the results were reported and agreed with Senior Management, and that the assessment and testing results were communicated to the Audit Committee throughout the year.	
			Inspected the documented annual Financial Risk Assessment and ascertained that it included financial and fraud risks, the results were reported and agreed with Senior Management, and that the assessment and testing results were communicated to the Audit Committee throughout the year.	No deviations noted.
ELC-17-01	Internal Audit is independent of management and the Head of Internal Audit reports directly to the Chair of the Audit Committee. Personnel executing activities have the requisite level of experience and credentials to evaluate the company's internal control environment. The Internal Audit function assesses risks, evaluates the effectiveness of internal controls and regularly communicates results to the business, management, and the Audit Committee based on the Institute of Internal Auditors professional standards. Issues identified by both internal and external auditors are tracked and monitored to ensure timely remediation of issues and	<u>CC.4.1</u> <u>CC.4.2</u>	Inquired of the control owner and ascertained that an independent and competent Internal Audit function existed and reported directly to the Audit Committee regarding review and evaluation of the company's internal control environment and risks assessment. Further inquired that issues identified were reported to both management and the Audit and Risk Committee.	No deviations noted.
			Inspected the meeting minutes of the Audit and Risk Committee meeting, and ascertained that Internal Audit communicated and covered procedures on performing evaluation, review of the company's internal control environment, and the consideration of the risk assessment in accordance with Institute of Internal Auditors professional standards.	No deviations noted.



Entity Level Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
	implementation of controls. Issues are periodically reported to both management and the Audit and Risk Committee.		Inspected the meeting minutes of the Audit and Risk Committee meeting, and ascertained that issues identified by both internal and external auditors were communicated to both management and the Audit and Risk Committee and tracked for timely remediation of issues and implementation of controls.	No deviations noted.
SP.1.0	The Security Policy, supporting standards and procedures have been formally established and documented in accordance with Okta's risk objectives, applicable legal and regulatory requirements, approved by the security function, and communicated to all employees and relevant external parties. The policy statements and references to security standards and procedures are reviewed on a periodic basis to address changes to the internal and external environment and to support the security function's objective of continuous improvement of the organization's security capabilities.	<u>CC.1.1</u> <u>CC.1.4</u> <u>CC.1.5</u> <u>CC.2.2</u> <u>CC.2.3</u> <u>CC.3.1</u> <u>CC.3.2</u> <u>CC.5.1</u> <u>CC.5.2</u> <u>CC.5.3</u>	Inquired of the control owner and ascertained that Okta had a Security Policy formally established and documented, approved by the security function, and communicated to all employees and relevant external parties.	No deviations noted.
			Inspected the Security Policy and ascertained that a Security Policy was established and documented to support the security function's objective of continuous improvement of the organization's security capabilities. Further inspected that the Security Policy was reviewed on a periodic basis and communicated.	No deviations noted.
SP.4.0	Okta has established a communication strategy for the policies that is monitored, reported to management, and reviewed for improvements regularly. Significant changes to policies are communicated as necessary via team meetings, security awareness emails, and/or company-wide email or newsletter communications.	<u>CC.1.1</u> <u>CC.1.3</u> <u>CC.1.4</u> <u>CC.1.5</u> <u>CC.2.2</u> <u>CC.2.3</u> <u>CC.3.1</u> <u>CC.5.3</u>	Inquired of the control owner and ascertained that a communication strategy for the policies was established and monitored, reported to management, and reviewed for improvements regularly. Further ascertained that significant changes to policies were communicated as necessary.	No deviations noted.
			Inspected the intranet and ascertained that policies were available to all Okta employees worldwide.	No deviations noted.



Entity Level Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
			Inspected the significant change made for a sample of modified policies and ascertained that the significant change was communicated through various communication channels.	No deviations noted.
SP.5.0	Appropriate governance is defined and implemented to manage Okta's security program and Okta security risk. Okta defines organizational structures, reporting lines, authorities, roles, and responsibilities for security governance and security risk management. Okta appoints a senior security officer with the mission and resources to coordinate, develop, implement, and maintain an organization-wide security program.	<u>CC.1.2</u> <u>CC.1.3</u> <u>CC.1.4</u> <u>CC.2.2</u> <u>CC.5.1</u> <u>CC.5.3</u>	Inquired of the control owner and ascertained that a security governance program was defined and implemented to manage Okta's security program and security risk. Further inquired that an organizational structure, including roles and responsibilities, was established for the security governance and security risk management in place and that Okta appointed a senior security officer with the mission and resources to coordinate, develop, implement, and maintain an organization-wide security program.	No deviations noted.
			Inspected the Security Policy and ascertained that a Security Policy was established and documented to support the security function's objective of continuous improvement of the organization's security capabilities. Further inspected that the Security Policy was reviewed on a periodic basis and communicated.	No deviations noted.
			Inspected the organizational structure and ascertained the reporting lines, roles, and responsibilities were established. Further inspected that a senior security officer was appointed to coordinate, develop, implement, and maintain the security program.	No deviations noted.



Human Resource Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
ELC-03-02	The Company has an adequate organizational structure necessary to provide clear lines of accountability and authority across all functions and operating units of the company, including facilitating accurate and complete financial reporting. The organizational structure is periodically reviewed to ensure it meets the needs of the Company. HR creates job requisitions for all key roles, including key accounting and finance positions, to help ensure the company targets and hires qualified individuals.	<u>CC.1.1</u> <u>CC.1.4</u> <u>CC.2.2</u> <u>CC.5.3</u>	Inquired of the control owner and ascertained that the Company a regularly updated organizational structure necessary to provide clear lines of accountability and authority across all functions and operating units of the company. Further inquired that HR created job requisitions for all key roles to meet the Company targeted and hired qualified individuals.	No deviations noted.
			Inspected the organizational structure for a sample of new employees and ascertained that the organizational structure was reviewed and updated.	No deviations noted.
			Inspected the job requisition for a sample of new employees and ascertained that it was utilized by HR in making the hiring decision, and the employee met the qualifications of the job.	No deviations noted.
			Inspected the Okta Organizational Chart in OrgWiki and ascertained that it provided lines of accountability and authority across all functions and operating units of the company, including facilitating accurate and complete financial reporting.	No deviations noted.
ELC-04-01	Prior to hiring, all employees (US and International) as well as contractors go through a background check through a 3rd Party Vendor. The HR Team goes into the 3rd Party Vendor website portal to verify the background check is complete prior to onboarding a new employee.	<u>CC.1.4</u>	Inquired of the control owner and ascertained that background check was performed and completed for all employees and contractors prior to hiring and onboarding.	No deviations noted.
			Inspected the background check results for a sample of new hire employees and contractors and ascertained that background check was completed prior to hiring.	No deviations noted.



Human Resource Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
ELC-05-01	Annually, the Company completes an employee alignment review process (Okta Alignment Review "OAR"), which is documented and retained in Workday. Employees are expected to complete the OARs, which consists of VMT's, feedback, and review.	<u>CC.1.1</u> <u>CC.1.4</u> <u>CC.2.2</u> <u>CC.5.3</u>	Inquired of the control owner and ascertained that an employee alignment review process (Okta Alignment Review or "OAR") was documented and retained in Workday on an annual basis.	No deviations noted.
			Inspected the Okta Alignment Review results for a sample of active employees as of September 30, 2024 and ascertained that the OARs were completed by Okta employees and documented in Workday.	No deviations noted.
HC.2.0	Okta defines a disciplinary policy and process for personnel failing to comply with established information security policies and procedures.	<u>CC.1.1</u> <u>CC.1.5</u>	Inquired of the control owner and ascertained that a disciplinary policy and process for non-compliance for personnel was defined and established.	No deviations noted.
			Inspected Okta's disciplinary action policy and ascertained that a process was in place to take action against policy violations.	No deviations noted.
			Inspected the reported disciplinary action documentation for a sample of employees and ascertained that the disciplinary action was performed based on Okta's Disciplinary Process Policy.	No deviations noted.
HC.3.0	The Code of Business Conduct and Employee Handbook are published and available to personnel on the company portal, outline how the company and its subsidiaries conduct business, describe the company's shared values, and describe responsibilities and expected behavior regarding system usage. The organization also establishes terms and conditions of employment, including third-party contractual agreement	<u>CC.1.1</u> <u>CC.1.3</u> <u>CC.1.5</u> <u>CC.2.2</u> <u>CC.5.2</u> <u>CC.5.3</u>	Inquired of the control owner and ascertained that the Code of Conduct and Employee Handbook were available and accessible to employees and contractors. Further inquired that the terms and conditions of employment were included in the Code of Conduct.	No deviations noted.
			Inspected the Code of Conduct and Employee Handbook and ascertained that the Code of Conduct	No deviations noted.



Human Resource Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
	requirements, stating responsibilities for security.		and Employee Handbook was available and accessible to employees and contractors, and it included the company's shared values, responsibilities, and expected behavior regarding system usage.	
TA.1.0	Privacy and information security training and awareness is mandatory for employees and contractors upon hire. Training compliance is recorded, monitored, and managed.	<u>CC.1.4</u> <u>CC.1.5</u> <u>CC.2.2</u>	Inquired of the control owner and ascertained that privacy and information security training and awareness was mandatory for all employees and contractors upon hire and on an annual basis.	No deviations noted.
			Inspected the security awareness training and privacy training material and ascertained that training topics covered employees and contractors' ability to detect, prevent, and contain potential security threats, protect confidential information, and proper security measures.	No deviations noted.
			Inspected the acknowledgement of completion of the privacy and information security training for a sample of new employees and contractors, and ascertained that the Privacy and Information Security Training and Awareness was completed as part of the onboarding process.	No deviations noted.
			Inspected the acknowledgement of completion of the privacy and information security training for a sample of active employees and contractors and ascertained that the Privacy and Information Security Training and Awareness was completed annually.	Deviation noted. For one (1) of 25 sampled active employees, the security awareness



Human Resource Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
				training was not completed timely.
			Inspected the email notification and ascertained that appropriate measures were in place to monitor the timely completion of the training.	No deviations noted.
Management Response: Okta monitors and escalates issues of overdue training, including the Security Awareness Training. This includes sending ongoing notifications to an employee and their direct supervisor when an employee's training becomes overdue. This feedback and continuous follow-up help to ensure the completion of the required training. The sampled employee has completed the training as of January 22, 2025. Okta is in the process of exploring access limitations or other measures in case of non-compliance.				



Customer Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
TP.6.0	Okta has developed and established standardized contractual clauses and provisions for customer service agreements, ensuring alignment with the defined business, legal, and regulatory requirements. This includes privacy and security obligations, capacity planning, termination clauses, and clearly assigned roles and responsibilities for both parties. Additionally, Okta develops and implements communication channels to effectively relay any modifications made to its service agreements to its customers.	<u>CC.2.3</u> <u>CC.9.2</u>	Inquired of the control owner and ascertained that Okta developed and established standardized contractual clauses and provisions for customer service agreements that included privacy, security obligations, capacity planning, termination clauses, and assigned roles and responsibilities for both parties. Further inquired that communication channels were in place to relay any modifications made to the service agreements.	No deviations noted.
			Inspected the standardized contractual clauses and provisions for a sample of customers and ascertained that the contracts included privacy and security obligations, capacity planning, termination clauses, and clearly assigned roles and responsibilities for both parties.	No deviations noted.
			Inspected Okta's communication channels and ascertained that modification of service agreement from Okta to its customers were communicated.	No deviations noted.
DP.11.0	Personal data retention and disposal processes are implemented to securely delete, de-identify, or otherwise obfuscate personal data when no longer required for the purpose for which it was collected (or if otherwise legally required).	<u>CC.2.1</u> <u>C.1.1</u> <u>C.1.2</u>	Inquired of the control owner and ascertained that personal data retention and disposal processes were implemented to securely delete, de-identify, or otherwise obfuscate personal data when no longer required for the purpose for which it was collected (or if otherwise legally required).	No deviations noted.
			Inspected the relevant configurations for the data disposal and ascertained that a script was enforced to securely dispose of information (delete, de-identify, or obfuscate personal data when no longer required).	No deviations noted.



Customer Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
			Inspected the customer organization profile for a sample of organization deletion requests and ascertained that disposal processes were implemented to securely delete, de-identify, or otherwise obfuscate personal data when no longer required for the purpose for which it was collected (or if otherwise legally required).	No deviations noted.
IM.15.0	Privileged access to customer environments by Okta personnel is granted upon customer requests and access automatically expires within 24 hours.	<u>CC.6.1</u> <u>CC.6.2</u> <u>CC.6.3</u>	Inquired of the control owner and ascertained that privileged access to customer environments by Okta personnel was limited to appropriate users for customer support purposes and was granted upon customer requests. Further inquired that access automatically expires within 24 hours.	No deviations noted.
			Inspected the relevant configurations for privileged access to customer environments and ascertained that privileged access required that the customer enables the Okta personnel.	No deviations noted.
			Observed an attempt to access the customer environment and ascertained that the Okta personnel did not have the ability to enable access to the customer environment.	No deviations noted.
			Inspected the relevant configurations for the access expiration and ascertained that access to the customer environment was set to automatically expire within 24 hours.	No deviations noted.



Customer Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
			Inspected the access expiration history and ascertained that access of the Okta personnel was automatically removed within 24 hours from the date the access was enabled.	No deviations noted.
SP.7.0	Customer requests are recorded and tracked within an internal ticketing system through resolution. The ticketing system is utilized to document, prioritize, escalate, and resolve problems affecting contracted services.	<u>CC.6.1</u> <u>CC.6.2</u> <u>CC.6.3</u>	Inquired of the control owner and ascertained that customer requests were recorded and tracked within an internal ticketing system through resolution. The ticketing system is utilized to document, prioritize, escalate, and resolve problems affecting contracted services.	No deviations noted.
			Inspected customer communication for a sample of customer requests and ascertained that the request was recorded and tracked through resolution timely.	No deviations noted.



Change Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
CM.1.0	Okta follows a documented change control and release process, which includes: 1) Change initiation/request (includes impact assessments, prioritization, and communication to affected internal and external users); 2) Appropriate testing, reviews and approvals for changes to Okta platform, service, application, and production ecosystem (e.g., hardware, databases, environments, systems, etc.) that are not part of the Okta platform or application; and 3) Deployment of releases and acceptance criteria of releases. The results of changes and releases are monitored, analyzed, and documented.	<u>CC.2.1</u> <u>CC.2.2</u> <u>CC.2.3</u> <u>CC.6.8</u> <u>CC.8.1</u>	Inquired of the control owner and ascertained that Okta followed a documented change control and release process for change initiation/request, change testing, and change deployment.	No deviations noted.
			Inspected the relevant configurations for the branch protection rules for all the in-scope repositories and ascertained that peer review approval and successful testing were enforced prior to deployment.	No deviations noted.
			Observed an attempt to merge a pull request without a peer review approval and ascertained that the pull request was not allowed to be merged for deployment.	No deviations noted.
			Observed an attempt to merge a pull request without a successful testing and ascertained that the pull request was not allowed to be merged for deployment.	No deviations noted.
			Inspected the peer review approval and testing results for a sample of merged pull requests, and ascertained that changes were peer reviewed by an independent reviewer and changes were successfully tested prior to deployment.	No deviations noted.
			Inspected the release notes for a sample of releases, and ascertained that changes made into the product functionality were communicated to external users.	No deviations noted.



Change Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
CM.2.0	Okta analyzes changes to the information system to determine potential system impacts prior to change implementation and immediately after implementation. Services that are new or changing are implemented in accordance with the defined service management objectives and requirements.	CC.2.1 CC.3.4 CC.6.8 CC.8.1	Inquired of the control owner and ascertained that the Product Team analyzed changes to the information system to determine potential system impacts prior to change implementation and immediately after implementation. Further inquired that new or modified services were implemented in accordance with the defined service management objectives and requirements.	No deviations noted.
			Inspected the Jira ticket for a sample of new or modified services and ascertained that changes to the services were analyzed to determine potential system impacts prior to change implementation and immediately after implementation. Further inspected that the changes to the services were implemented in accordance with the defined service management objectives and requirements.	No deviations noted.
CM.3.0	Okta limits privileges to migrate changes (i.e., software packages) to the production environment. Access to source code is restricted and managed.	CC.2.1 CC.6.8 CC.8.1	Inquired of the control owner and ascertained that access to migrate changes to the source code and the production environment was limited.	No deviations noted.
			Inspected the list of users with access to the source code and ascertained that access to the source is restricted to appropriate users.	No deviations noted.
			Inspected the list of users with access to the production environment and ascertained that developers do not have access to migrate their own change to the production environment is restricted to appropriate users.	No deviations noted.



Change Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
			Inspected the relevant configurations for monitoring branch protection settings and ascertained that modification to the branch protection settings automatically created a ticket for monitoring.	No deviations noted.
			Inspected the ticket for a sample of modification to the branch protection settings and ascertained that the modification was investigated and resolved timely.	No deviations noted.
CM.4.0	Development, testing, and production environments and instances are segmented to reduce the risks of unauthorized access or changes to the production environment.	<u>CC.2.1</u> <u>CC.6.8</u> <u>CC.8.1</u>	Inquired of the control owner and ascertained that development, testing, and production environments and instances were segmented to reduce the risk of unauthorized access or changes to the production environment.	No deviations noted.
			Inspected the AWS environment and ascertained that the development, testing, and production instances were segmented to reduce the risks of unauthorized access or changes to the production environment.	No deviations noted.
CF.1.0	A configuration management function and technology exist to implement, maintain, and control configuration of systems and other infrastructure elements (including hardware, software, applications, and services). The function requires the identification of baseline configurations (i.e., original versions) of hardware, software, applications, and services. Current and prior configurations are captured and	<u>CC.2.1</u> <u>CC.5.2</u> <u>CC.7.1</u> <u>CC.8.1</u>	Inquired of the control owner and ascertained that configuration management function and technology existed to implement, maintain, and control configuration of systems and other infrastructure elements.	No deviations noted.
			Inspected the configuration management tool and ascertained that technology existed to implement, maintain, and control configuration of systems and other infrastructure elements.	No deviations noted.



Change Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
	maintained in the central repository to support rollback.		Observed an attempt to change the configuration for an Okta environment and ascertained that the current and prior configurations were captured and maintained in the central repository to support rollback.	No deviations noted.
SD.2.0	Security and privacy requirements are taken into account while allocating resources for new information system development efforts or changes to existing information systems and applications.	<u>CC.3.1</u> <u>CC.4.1</u> <u>CC.5.1</u> <u>CC.5.2</u> <u>CC.6.1</u>	Inquired of the control owner and ascertained that security and privacy requirements were considered while allocating resources for new information system development efforts or changes to existing information systems and applications.	No deviations noted.
			Inspected the ticket for a sample of change releases and ascertained that security and privacy requirements were taken into account on development efforts or changes to existing information systems and applications.	No deviations noted.
SD.3.0	Validation checks are incorporated within applications to ensure accurate processing of information. The validation process involves verifying the input and output of programs and applications within the information system. In case of errors, appropriate error messages are generated, containing the necessary details for authorized personnel to take corrective actions. These error messages are designed to provide the required information without disclosing any data	<u>CC.2.1</u>	Inquired of the control owner and ascertained that validation checks were incorporated for accurate processing of information, and errors were generated and resolved. Further ascertained that in case of errors, an error message was generated.	No deviations noted.
			Inspected the relevant configurations for the validation checks and ascertained that validation checks were in place to verify the input and output of programs and applications within the application for accurate processing of information.	No deviations noted.



Change Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
	that could potentially be exploited by adversaries.		Inspected the validation check results for a sample of change releases and ascertained that the validation check verified the input and output of the program within the information system for accurate processing of information. Further ascertained that if there is an error, an error message was generated.	No deviations noted.



Access Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
IM.1.0	A formal access registration and initial provisioning process for employees and authorized third parties is in place for Okta to assign access rights for all user types to all systems and services, in alignment with policy and standards.	<u>CC.5.2</u> <u>CC.6.1</u> <u>CC.6.2</u> <u>CC.6.3</u>	Inquired of the control owner and ascertained that a formal access registration and initial provisioning process was in place to assign access rights for all user types.	No deviations noted.
			Inspected the ticket for a sample of provisioned users and ascertained that appropriate approval was completed prior to provisioning of access to all user types to systems and services in alignment with policy and standards.	No deviations noted.
IM.2.0	Okta employs the principle of least privilege and separation of duties. Only authorized access is allowed for users which are necessary to accomplish assigned tasks in accordance with organizational missions and business functions.	<u>CC.5.2</u> <u>CC.6.1</u> <u>CC.6.2</u> <u>CC.6.3</u> <u>C.1.1</u>	Inquired of the control owner and ascertained that access was allowed for users based on the principle of least privilege and separation of duties.	No deviations noted.
			Inspected the ticket for a sample of provisioned users to the product and ascertained that access requests were necessary for the users to accomplish assigned tasks in accordance with organizational missions and business functions.	No deviations noted.
IM.5.0	The organization employs mechanisms to notify individuals and teams responsible for disabling access upon termination of an individual or for modifying access when there is a change in the role. A formal user deprovisioning process is in place to manage and enforce the timely revocation of logical access to information and system resources in the result of a termination of a user's account, inactive accounts, and anonymous accounts.	<u>CC.6.1</u> <u>CC.6.2</u> <u>CC.6.3</u> <u>CC.6.4</u>	Inquired of the control owner and ascertained that a formal user deprovisioning process was in place to terminate a user's account, inactive accounts, and anonymous accounts.	No deviations noted.
			Inspected the termination policy and ascertained that a process was in place to terminate a user's account, inactive accounts, and anonymous accounts.	No deviations noted.
			Inspected tickets for a sample of terminated users and ascertained that notification to individuals and teams	No deviations noted.



Access Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
			responsible were made to disable access timely. Further inspected that the removal of access to the information and system resources of the user, inactive accounts, and anonymous accounts was performed in a timely manner.	
IM.6.0	User access reviews are performed at least once every 6 months. Modifications or removal of privileges is performed as necessary. An up-to-date record of the users or profiles of users who have authorized access to the information system is maintained.	<u>CC.6.2</u> <u>CC.6.3</u>	Inquired with the control owner and ascertained that review of user access was performed at least once every 6 months by the designated service owners.	No deviations noted.
			Inspected the documented review for a sampled semi-annual user access review and ascertained that the review was performed completely, and timely, and inappropriate access identified was removed timely.	January 1, 2024 - May 31, 2024 Deviation noted. For the sampled user access review, the reviewer did not retain evidence that the listing used in the review is complete and accurate and did not review the appropriateness of the users



Access Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
				with access to the product. Further inspected the evidence of the review and ascertained that the reviewer only checked if the user continued to be active or was terminated. June 1, 2024 - November 30, 2024 Deviated noted. For the sampled user access review, the reviewer did not retain sufficient evidence that the listing used in the



Access Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
				review is complete and accurate.
Management Response: All privileged users that were included in the review were determined to be appropriate. Management agrees that additional evidence supporting completeness and accuracy of this control should be generated and retained moving forward.				
IM.7.0	Privileged user access is established and administered on a controlled basis and is limited to only what is required for users and services to undertake their duties. Privileged users are assigned a dedicated privileged account to be used solely for tasks requiring privileged access.	<u>CC.6.1</u> <u>CC.6.2</u> <u>CC.6.3</u>	Inquired of the control owner and ascertained that privileged user access was limited to only what was required for users and services to undertake their duties.	No deviations noted.
			Inspected the ticket for a sample of provisioned privileged users and ascertained that privileged user access was established and administered on a controlled basis and was limited to only what was required for users and services to undertake their duties. Further inspected that necessary approvals were obtained prior to provisioning.	No deviations noted.
IM.9.0	Lock out features are enabled to restrict access after a certain amount of access requests. The account is locked out for a specific duration or until an administrator enables the user account. The user is notified upon successful/unsuccessful logon.	<u>CC.6.1</u> <u>CC.6.6</u>	Inquired of the control owner and ascertained Okta had defined lockout features to restrict access after a certain number of access requests.	No deviations noted.
			Inspected the relevant configurations for lock out and ascertained that the lockout features were in line with the company policy.	No deviations noted.
			Inspected the log of a sampled user attempting to log in after a number of attempts and ascertained that the user was locked-out after a certain number of access	No deviations noted.



Access Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
			requests. Further inspected that access was only re-enabled after an administrator unlocks the account.	
IM.11.0	Multi Factor authentication methods are implemented for access to the network and information systems by employees, administrators, and authorized third parties.	<u>CC.6.1</u> <u>CC.6.6</u>	Inquired of the control owner and ascertained that multi-factor authentication was required and enforced to access the network and information systems.	No deviations noted.
			Inspected the relevant configurations for authentication and ascertained that multi-factor authentication method was used to authenticate access to the network and information systems.	No deviations noted.
IM.12.0	A formal process exists for allocating and managing passwords and other user authentication mechanisms. Passwords and other access authenticators are securely allocated, managed, and stored in accordance with policies.	<u>CC.6.1</u>	Inquired of the control owner and ascertained that formal process existed for allocating and managing passwords and other user authentication mechanisms.	No deviations noted.
			Inspected the Password Policy and ascertained that the policy included mechanisms where passwords/access authenticators were securely allocated, managed, and stored in accordance with the policies. Further inspected that the policy was reviewed and approved at least annually.	No deviations noted.
IM.13.0	Password configurations are established, implemented, and enforced in alignment with industry, government, and other compliance requirements. Password management systems are interactive and ensure quality passwords.	<u>CC.6.1</u> <u>CC.6.6</u>	Inquired of the control owner and ascertained Okta had a defined password policy and password configurations were implemented based on the policy.	No deviations noted.
			Inspected the relevant configurations for password and ascertained that the settings were compliant with the password policy.	No deviations noted.



Access Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
NS.8.0	Remote access is appropriately controlled and monitored, and allowed only by means of an Okta-approved VPN client.	<u>CC.6.1</u> <u>CC.6.6</u> <u>CC.6.7</u>	Inquired of the control owner and ascertained that remote access was controlled and monitored by requiring an Okta approved VPN client.	No deviations noted.
			Inspected the relevant configurations for remote access and ascertained that there was an access registration and initial provisioning configuration in place to assign access rights to all user types.	No deviations noted.
			Observed an attempt to access remotely and ascertained that VPN was required to access the Okta production systems.	No deviations noted.
			Inspected the ticket for a sample of provisioned users and ascertained that appropriate approval was required prior to provisioning of VPN access to all user types to systems and services in alignment with policy and standards.	No deviations noted.
DS.6.0	A formal management system and associated process exists to securely manage and rotate keys.	<u>CC.6.6</u> <u>CC.6.7</u>	Inquired of the control owner and ascertained that a process was in place to securely manage keys using a key management system. Further inquired and ascertained that a formal key management system and associated processes existed to manage keys issued by the trusted Certification Authorities.	No deviations noted.
			Inspected the ticket for a sample of Secure Shell Protocol ("SSH") keys provisioned and ascertained that a process was in place to securely manage keys using a key management system.	No deviations noted.



Access Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
			Inspected the relevant configurations in the key management system and ascertained that secret/private keys were rotated at least annually and public keys were encrypted.	No deviations noted.



Data Security Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
AM.1.0	An asset life cycle management service exists. An inventory of all information assets and IT assets (e.g., physical assets, hardware, software, and information), is developed and updated on a periodic basis. Each IT asset and information asset has an owner who is accountable for protecting the asset. The asset inventory captures details such as asset name, type, location, owner, description, status and unique identifier.	<u>CC.2.1</u> <u>CC.3.2</u> <u>CC.6.1</u> <u>CC.6.4</u> <u>CC.6.5</u> <u>CC.6.8</u> <u>CC.8.1</u>	Inquired of the control owner and ascertained that an asset life cycle management service was available and an inventory of all information assets and IT assets were maintained and updated on an as needed basis. Further inquired that the asset inventory captured the details such as asset name, type, location, owner, description, status, and unique identifier.	No deviations noted.
			Inspected the inventory of the information assets and IT assets and ascertained that it was maintained and updated as needed. Further inspected that the asset inventory captured the details such as asset name, type, location, owner, description, status, and unique identifier.	No deviations noted.
			Inspected the logs for a sample of assets and ascertained that the asset was maintained in the inventory and captured the details such as asset name, type, location, owner, description, status, and unique identifier.	No deviations noted.
AM.3.0	The use of writable, removable media and personally owned, removable media in organizational systems is controlled and monitored. The use of removable media is prohibited in organizational information systems when such devices have no identifiable owner.	<u>CC.6.7</u> <u>CC.6.8</u>	Inquired of the control owner and ascertained that the use of writable, removable media and personally owned removable media was controlled and monitored. Further inquired of the control owner and ascertained that the user of removable media was prohibited.	No deviations noted.
			Inspected the relevant configurations for MacOS and Windows devices and ascertained that mass storage, media transfer protocol, and picture transfer protocol were blocked.	No deviations noted.



Data Security Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
			Observed an attempt to use a removable media for a MacOS device and a Windows device, and ascertained that the use of removable media was prohibited.	No deviations noted.
AM.6.0	Policies for acceptable use of information technology assets have been established, made accessible to personnel, and are reviewed/updated on a periodic basis.	<u>CC.6.7</u>	Inquired of the control owner and ascertained those policies for Acceptable Use Standard policy was established, made accessible to personnel, and were reviewed and updated (if applicable) at least annually.	No deviations noted.
			Inspected the policy for Acceptable Use Standard policy and ascertained that it was made accessible to personnel, reviewed, and updated at least annually.	No deviations noted.
AM.9.0	Assets and equipment are securely disposed of, if no longer required. Sanitization procedures are formally documented and are in alignment with federal and organization standards and policies.	<u>CC.6.4</u> <u>CC.6.5</u> <u>CC.6.7</u> <u>C.1.1</u> <u>C.1.2</u>	Inquired of the control owner and ascertained that assets and equipment were securely disposed of and formal sanitization procedures were performed.	No deviations noted.
			Inspected the Okta's Asset Management Standard and ascertained that sanitization procedures were formally documented and aligned with Data Classification and Handling Standard.	No deviations noted.
			Inspected the certification of data destruction for a sample of disposed assets and ascertained that the assets were sanitized in alignment with federal and organization standards and policies.	No deviations noted.
AM.10.0	IT assets are protected against unauthorized access, misuse or corruption during transit, within, or outside of Okta's premises.	<u>CC.6.4</u> <u>CC.6.5</u> <u>CC.6.7</u>	Inquired of the control owner and ascertained that IT assets were protected against unauthorized access, misuse, or corruption during transit, within, or outside of Okta's premises.	No deviations noted.



Data Security Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
			Inspected the relevant configurations for MacOS and Windows and ascertained that there were mechanisms in place to protect the IT assets against unauthorized access, misuse, or corruption during transit, within, or outside of Okta's premises.	No deviations noted.
DS.1.0	Okta has established and implemented a comprehensive records management service that includes creating and maintaining authentic, reliable, and usable records, and protecting the integrity of those records for as long as required by policy or regulatory requirement, including during information transfers. Hard copy and digital data retention and deletion policies and procedures are established and enforced in accordance with applicable laws, regulations, and contractual obligations. Retention periods have been defined for each type of data.	<u>CC.2.1</u> <u>C.1.1</u>	Inquired of the control owner and ascertained that Okta maintained and enforced a data classification and handling policy, including retention and deletions.	No deviations noted.
			Inspected Okta's Data Classification and Handling Standard Policy and ascertained that the policy included guidelines on classifying data and information.	No deviations noted.
			Inspected the documentation for each data classification type and ascertained that it was assigned a classification level according to Okta's Data Classification and Handling Standard Policy.	No deviations noted.
DS.2.0	Okta maintains an encryption management standard which outlines compliance, data encryption, and key management protocols.	<u>CC.6.1</u> <u>CC.6.7</u>	Inquired of the control owner and ascertained that Okta maintained an encryption management standard which outlined compliance, data encryption, and key management protocols.	No deviations noted.
			Inspected the Cryptographic and Encryption Policy, and ascertained it outlined compliance, data encryption, and key management protocols, and it was reviewed and approved.	No deviations noted.



Data Security Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
DS.4.0	Okta protects organizationally classified data types at rest through the use of security controls, including encryption and cryptographic controls, in alignment with security standards.	<u>CC.6.1</u> <u>CC.6.7</u> <u>C.1.1</u>	Inquired of the control owner and ascertained that organizationally classified data types were protected at rest through the use of security controls, including encryption and cryptographic controls, in alignment with the security standards.	No deviations noted.
			Inspected the relevant configurations of the database and ascertained that encryption at rest was enabled in alignment with the security standards.	No deviations noted.
DS.5.0	Okta protects organizationally classified data types in transmission through the use of security controls, including encryption and cryptographic controls, in alignment with security standards.	<u>CC.6.1</u> <u>CC.6.7</u>	Inquired of the control owner and ascertained that organizationally classified data types were protected in transit through the use of security controls, including encryption and cryptographic controls, in alignment with security standards.	No deviations noted.
			Inspected the TLS Certificate and ascertained that encryption in transit was enabled in alignment with the security standards.	No deviations noted.
			Observed an attempt to access a customer instance using HTTP and ascertained that the page was rerouted to HTTPS.	No deviations noted.
SM.1.0	Okta configures logging mechanisms to enable the identification and tracking of unauthorized system activity. This includes failed and successful login attempts, privileged account activity, and logging of additional activity as configured by the customer.	<u>CC.7.1</u> <u>CC.7.2</u>	Inquired of the control owner and ascertained that logging mechanisms were configured to identify and track unauthorized system activity, including failed and successful login attempts, privileged account activity, and logging of additional activity as configured by the customer.	No deviations noted.



Data Security Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
			Inspected the relevant configurations to monitor failed and successful login attempts, and privileged account activity, and ascertained that logging mechanisms were in place to identify and track unauthorized system activity.	No deviations noted.
SM.2.0	Alerts from multiple sources are captured, correlated, reviewed, and reported on. Procedures are in place to respond to anomalies and indications of inappropriate, suspicious, or abnormal activity detected during log reviews.	<u>CC.7.1</u> <u>CC.7.2</u>	Inquired of the control owner and ascertained that alerts were captured and reviewed, and procedures were in place to respond to anomalies during the log reviews.	No deviations noted.
			Inspected the notification for a sample of security alerts and ascertained that alerts were captured, correlated, reviewed, and reported on.	No deviations noted.
SM.7.0	Okta conducts security event monitoring activities using automation tools (e.g., SIEM tools) to detect unauthorized connections, devices, events, network services, etc., and conducts initial analysis of events. Monitored events are further analyzed to understand attack targets and methods.	<u>CC.7.1</u> <u>CC.7.2</u>	Inquired of the control owner and ascertained that Okta used automation tools to monitor security events to detect unauthorized connections, devices, events, network services. Further inquired that Okta performed analysis of the events to understand attack targets and methods.	No deviations noted.
			Inspected the ticket for a sample of alerts and ascertained that alert was reviewed and resolved timely.	No deviations noted.
VM.2.0	Okta participates in special interest groups, security associations, and security forums to obtain insights about security programs, security risk and threat landscape, system security and vulnerability alerts, advisories, and directives. Okta shares information from alerts, advisories,	<u>CC.3.2</u> <u>CC.3.4</u>	Inquired of the control owner and ascertained that Okta participated in special interest groups, security associations, and security forums to obtain insights on security programs, security risks, threat landscape, system security and vulnerability alerts, advisories, and directives. Further inquired that Okta shared	No deviations noted.



Data Security Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
	and directives within the organization. Appropriate actions are taken in response to information system security alerts and advisories.		information from alerts, advisories, and directives within the organization and appropriate actions were taken to respond to the alert and advisories.	
			Inspected the security subscriptions in Slack and ascertained that security programs, security risk and threat landscape, system security and vulnerability alerts, advisories, and directives were shared within the organization and discussed with the members of the Security Team.	No deviations noted.
VM.5.0	Vulnerability scans and rescans are performed on both external and internal facing systems on a periodic basis to identify and remediate system flaws and vulnerabilities. Commercial and proprietary vulnerability scanning tools are configured to identify vulnerabilities.	<u>CC.3.2</u> <u>CC.3.4</u> <u>CC.6.8</u> <u>CC.7.1</u> <u>CC.7.2</u> <u>CC.7.3</u> <u>CC.7.4</u> <u>CC.8.1</u>	Inquired of the control owner and ascertained that vulnerability scans and rescans were performed on both external and internal facing systems on a monthly basis in order to identify and remediate system flaws and vulnerabilities. Further inquired that commercial and proprietary vulnerability scanning tools were configured to identify vulnerabilities.	No deviations noted.
			Inspected the relevant configurations for vulnerability scanning and ascertained that the tool was configured to identify vulnerabilities.	No deviations noted.
			Inspected the ticket for a sample of vulnerabilities identified from the vulnerability scanning tool and ascertained that the vulnerability was reviewed and investigated timely.	No deviations noted.
			Inspected the relevant configurations for code scanning and ascertained that the tool was configured to identify vulnerabilities.	No deviations noted.



Data Security Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
			Inspected the ticket for a sample of code scanning vulnerabilities and ascertained that the vulnerability was reviewed and investigated timely.	No deviations noted.
			Inspected the penetration testing result performed by a third party and ascertained that identified vulnerabilities and system flaws were reviewed and investigated timely.	No deviations noted.
			Inspected the penetration testing result performed by Okta and ascertained that identified vulnerabilities and system flaws were reviewed and investigated timely.	No deviations noted.
VM.6.0	Firmware updates and patches are incorporated, tested, and implemented in a timely fashion based on identified vulnerabilities.	<u>CC.7.1</u> <u>CC.7.3</u> <u>CC.7.4</u> <u>CC.8.1</u>	Inquired of the control owner and ascertained that firmware updates and patches were incorporated, tested, and implemented in a timely fashion based on identified vulnerabilities. Further inquired that operating systems, applications, and hardware devices that were no longer supported by their vendors were updated to a vendor supported version or replaced with an alternative vendor supported version.	No deviations noted.
			Inspected the relevant configurations and ascertained that firmware updates and patches were configured to be automatically installed on Okta-issued devices.	No deviations noted.
			Inspected the firmware for each type of OS device and ascertained that the update was automatically implemented timely.	No deviations noted.



Risk Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
ELC-07-03	Annually, the Company maintains an Enterprise Risk Management (ERM) program to identify, examine, and communicate risks (including financial reporting and fraud risks) at various entity levels. The results of the annual Enterprise Risk Assessment are discussed with the Management and the Audit Committee.	<u>CC.3.1</u>	Inquired of the control owner and ascertained that an Enterprise Risk Management ("ERM") program was maintained to identify, examine, and communicate risks (including financial reporting and fraud risks). Further inquired that the results of the annual Enterprise Risk Assessment were discussed with Management and the Audit Committee.	No deviations noted.
			Inspected the results of the enterprise risk assessment performed and ascertained that the enterprise risk assessment was discussed with Management and the Audit Committee.	No deviations noted.
ELC-11-01	The Security Team maintains a risk-based program to address the dynamic environment in which the Company operates. The team develops approaches to manage security risks identified from multiple sources. The Security team conducts periodic security assessments to help identify potential risks. Through policy, the Security Team defines and communicates ownership and responsibilities for data integrity, information classification, and security. The Security Team periodically provides the Board of Directors, the Risk Oversight Committee, and/or the Audit Committee with an overview of cybersecurity risks and steps that management has taken to mitigate such risks.	<u>CC.3.1</u> <u>CC.3.4</u> <u>CC.4.2</u> <u>CC.5.1</u>	Inquired of the control owners and ascertained that a risk-based program was maintained by the Security Team to identify and manage security risks identified from multiple sources. Further inquired that ownership and responsibilities were defined and communicated periodically.	No deviations noted.
			Inspected the Security Risk Assessment policy and ascertained that the Security Team defined and communicated ownership and responsibilities for data integrity, information classification, and security.	No deviations noted.
			Inspected the Security Risk Assessment and ascertained that the periodic security assessments were performed and it was appropriately reported to the Board of Directors, Risk Oversight Committee and the Audit Committee.	No deviations noted.



Risk Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
			Inspected the Security Risk Assessment and ascertained that it was appropriately reported to the Board of Directors, Risk Oversight Committee, and the Audit Committee.	No deviations noted.
RM.2.0	Okta has a formally documented, reviewed, and maintained risk assessment methodology that incorporates identifying and documenting security threats and vulnerabilities by conducting security risk assessments annually and as needed on an ad hoc basis, and prioritizing relevant threats and vulnerabilities based on likelihood and impact to organizational operations, organizational assets, and individuals. Security Risk Management manages risk ownership, and results are communicated and reported to leadership for review and approval.	<u>CC.3.1</u> <u>CC.3.2</u> <u>CC.3.3</u> <u>CC.3.4</u> <u>CC.5.1</u>	Inquired of the control owners and ascertained that a formal risk assessment methodology was defined and maintained to identify and document security threats and vulnerabilities, as well as prioritizing relevant threats and vulnerabilities based on likelihood and impact to organizational operations, organizational assets, and individuals. Further inquired that results of the security risk assessment were communicated and reported.	No deviations noted.
			Inspected the formal risk assessment methodology and ascertained that it identified and documented security threats and vulnerabilities, as well as prioritized relevant threats and vulnerabilities based on likelihood and impact to organizational operations, organizational assets, and individuals.	No deviations noted.
			Inspected the Security Risk Assessment and ascertained that it was completed in accordance with the risk assessment methodology, which included likelihood, impact, and risk treatment strategies.	No deviations noted.
			Inspected the Security Risk Assessment and ascertained that it was appropriately reported to the Board of Directors, Risk Oversight Committee and the Audit Committee.	No deviations noted.



Risk Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
RM.3.0	Okta has a defined and documented risk response methodology, inclusive of criteria to identify, prioritize and document security risk treatment strategies by level of impact to enterprise systems and information assets. Risk treatment strategies are applied to risks identified in annual Information Security risk assessments as well as ad hoc risk assessments as needed.	<u>CC.3.1</u> <u>CC.3.2</u> <u>CC.4.2</u> <u>CC.5.1</u>	Inquired of the control owners and ascertained that Okta had a defined and documented risk response methodology to identify, prioritize, and document security risk treatment strategies by level of impact to enterprise systems and information assets. Further inquired that the security risk assessment was performed annually.	No deviations noted.
			Inspected the Security Risk Assessment and ascertained that it was completed in accordance with the risk assessment methodology, which included likelihood, impact, and risk treatment strategies.	No deviations noted.
			Inspected the Security Risk Assessment and ascertained that it was appropriately reported to the Board of Directors, Risk Oversight Committee and the Audit Committee.	No deviations noted.



Network Security and Incident Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
CF.2.0	Okta implements a defined set of hardware, software, application, and service baseline configurations settings.	<u>CC.7.1</u> <u>CC.8.1</u>	Inquired of the control owner and ascertained that baseline configurations were implemented based on a defined set of hardware, software, application, and services.	No deviations noted.
			Inspected the profile for MacOS and WindowsOS devices, and ascertained that a defined set of hardware, software, application, and service baseline settings were configured.	No deviations noted.
			Inspected the relevant configurations for a sample of MacOS and WindowsOS devices and ascertained that it was compliant with the system baseline requirements set by the company.	No deviations noted.
			Inspected the device information for a sampled MacOS and WindowsOS devices that was not compliant with baseline configurations and ascertained that appropriate resolution was implemented.	No deviations noted.
CF.5.0	Installation of software by users is controlled and monitored to avoid employees from installing vulnerable software on Okta's assets.	<u>CC.6.7</u> <u>CC.8.1</u>	Inquired of the control owner and ascertained that installation of software by users was controlled and monitored.	No deviations noted.
			Inspected the relevant configurations for installing software and ascertained that installation of vulnerable software was prohibited on Okta's assets.	No deviations noted.
			Inspected the list of installed applications for an Okta asset and ascertained that only Okta approved software was installed on the Okta's asset.	No deviations noted.



Network Security and Incident Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
			Observed an attempt to install a vulnerable software on an Okta asset and ascertained that vulnerable software was prohibited from installation.	No deviations noted.
CF.8.0	Okta implements antivirus/malware detection and malicious code protection technologies on all Okta managed endpoint devices and information systems and operational processes to support the detection, prevention and recovery from malicious code, such as malware and viruses.	<u>CC.6.7</u> <u>CC.6.8</u>	Inquired of the control owner and ascertained that antivirus, malware detection, and malicious code protection technologies on all Okta managed endpoint devices were implemented and managed to detect malware and viruses.	No deviations noted.
			Inspected the relevant configurations on Okta managed endpoint devices and ascertained that antivirus/malware software and malicious code protection were configured to detect, prevent, and recover from malware and viruses.	No deviations noted.
			Inspected the relevant configurations on Okta managed endpoint devices and ascertained that CrowdStrike is automatically installed for all endpoint devices and cannot be uninstalled by a user.	No deviations noted.
			Observed an attempt to uninstall CrowdStrike and ascertained that CrowdStrike cannot be uninstalled by a user.	No deviations noted.
IR.1.0	A program is established to define Okta's strategies, objectives, and governing requirements with regard to security incident response and management. Security incident alert thresholds are established, and incidents are	<u>CC.2.2</u> <u>CC.2.3</u> <u>CC.6.8</u> <u>CC.7.1</u> <u>CC.7.2</u>	Inquired of the control owner and ascertained that a security incident response and management program was established to define Okta's strategies, objectives, and governing requirements. Further inquired that security incident alert thresholds were established.	No deviations noted.



Network Security and Incident Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
	controlled and mitigated to prevent additional impact to business operations.	<u>CC.7.3</u> <u>CC.7.4</u> <u>CC.7.5</u>	Inspected the documentation of the Security Incident Response Management Program and ascertained that it included Okta's strategies, objectives, and governing requirements. Further inspected that security incident alert thresholds were established.	No deviations noted.
IR.2.0	Okta has established a comprehensive security incident response and management plan with supporting tools, tactics, and procedures to prepare, identify, contain, eradicate, recover, and learn from identified security incidents. The documentation is communicated to appropriate stakeholders, and is reviewed, updated, and approved on an annual basis.	<u>CC.2.2</u> <u>CC.2.3</u> <u>CC.5.2</u> <u>CC.7.2</u> <u>CC.7.3</u> <u>CC.7.4</u> <u>CC.7.5</u>	Inquired of the control owner and ascertained that Okta had a comprehensive security incident response and management plan established, reviewed, and communicated to appropriate stakeholders on an annual basis.	No deviations noted.
			Inspected the documentation of the comprehensive security incident response and ascertained that the documentation was communicated to appropriate stakeholders, and was reviewed, updated, and approved on an annual basis.	No deviations noted.
IR.4.0	The Security Incident Response and Management Team engages internal (e.g., legal, public relations) and external (e.g., law enforcement, designated authorities, third-parties, data subjects) parties to share information, as appropriate depending on the type of security incident, consistent with response procedures and regulatory requirements. Notification is provided to impacted stakeholders (e.g., customers, shareholders) and measures taken to mitigate the event are communicated.	<u>CC.2.2</u> <u>CC.2.3</u> <u>CC.3.2</u> <u>CC.7.2</u> <u>CC.7.3</u> <u>CC.7.4</u> <u>CC.7.5</u>	Inquired of the control owner and ascertained that the security incident response and management engaged with internal and external parties to share information, as appropriate. Further inquired that security incidents were communicated, and measures were taken to mitigate the security incident.	No deviations noted.
			Inspected the incident ticket for a sample of security incidents and ascertained that internal (e.g., legal, public relations) and external (e.g., law enforcement, designated authorities, third parties, data subjects) parties were engaged to share information, as appropriate depending on the type of security incident.	No deviations noted.



Network Security and Incident Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
			Inspected the incident ticket for a sample of reported security incidents and ascertained that notification was provided to impacted stakeholders (e.g., customers, shareholders) and measures taken to mitigate the event were communicated.	No deviations noted.
IR.5.0	Okta has established processes to modify and improve the security incident response and management according to lessons learned through post-mortem exercises to reduce the likelihood or impact of future incidents.	<u>CC.7.1</u> <u>CC.7.3</u> <u>CC.7.4</u> <u>CC.7.5</u>	Inquired of the control owner and ascertained that a process was in place to modify and improve the security incident response, including lessons learned through post-mortem exercises.	No deviations noted.
			Inspected the incident report for a sample of security incidents and ascertained that the incident resolution included post-mortem exercises to reduce the likelihood or impact of future incidents (if applicable).	No deviations noted.
NS.2.0	Okta manages boundary protection device interfaces (e.g., gateways, firewalls, routers, guards, encrypted tunnels) to secure and restrict connections to external or untrusted networks or systems, in alignment with enterprise architecture.	<u>CC.6.1</u> <u>CC.6.6</u> <u>CC.6.8</u> <u>CC.7.2</u> <u>CC.7.3</u>	Inquired of the control owner and ascertained that boundary protection device interfaces were managed by Okta to secure and restrict connections to external or untrusted networks.	No deviations noted.
			Inspected the relevant configurations of the network connection and ascertained that connections were secured and restricted external or untrusted networks or systems.	No deviations noted.
NS.3.0	Groups of information services, users, network segments, and information systems are segregated as necessary to improve network integrity and security. Subnetworks are implemented for publicly accessible system	<u>CC.6.1</u> <u>CC.6.6</u>	Inquired of the control owner and ascertained that network segregation was in place to improve network integrity and security. Further inquired that system components were segregated from the DMZ and other untrusted networks.	No deviations noted.



Network Security and Incident Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
	components that are physically or logically separated from internal networks. System components that store sensitive data (such as a database) are in an internal network zone and segregated from the DMZ and other untrusted networks.		Inspected the relevant configurations of the network segregation and ascertained that system components that stored sensitive data (such as a database) were in an internal network zone and segregated from the DMZ and other untrusted networks.	No deviations noted.
NS.4.0	Protection mechanisms are in place to manage denial of service and network attacks.	<u>CC.6.1</u> <u>CC.6.6</u> <u>CC.7.2</u>	Inquired of the control owner and ascertained that protection mechanisms were in place to manage denial of service and network attacks.	No deviations noted.
			Inspected the relevant configurations of the firewall and ascertained that configuration rules and policies were in place to manage denial of service and network attacks.	No deviations noted.



Availability Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
ER.1.0	Business continuity plans, which outline the dependencies and critical functions for delivery of critical services, are formally documented, approved, communicated, and maintained through annual reviews and updates.	<u>CC.7.5</u> <u>CC.9.1</u> <u>A.1.2</u> <u>A.1.3</u>	Inquired of the control owner and ascertained that a business continuity plan was formally documented, approved, communicated, and maintained annually.	No deviations noted.
			Inspected the business continuity plan and ascertained that the business continuity plan was documented, approved, and communicated annually.	No deviations noted.
			Inspected the business continuity plan and ascertained that it outlined the dependencies and critical functions for delivery of critical services.	No deviations noted.
ER.2.0	Disaster and functional recovery plans, outlining the actionable plan and processes to recover from a declared disaster, are formally documented, approved, communicated, and maintained through annual reviews and updates.	<u>CC.9.1</u> <u>A.1.3</u>	Inquired of the control owner and ascertained that disaster and functional recovery plans were in place, and was formally documented, approved, communicated and maintained.	No deviations noted.
			Inspected the disaster and functional recovery plans ("DFRPs"), and ascertained that it outlined the actionable plan and processes to recover from a declared disaster. Further inspected that the DFRPs were formally documented, approved, communicated, and maintained annually.	No deviations noted.
ER.3.0	Okta tests its business continuity plan on a periodic basis to verify its relevance and validate the effectiveness of established recovery strategy, action plan, recovery point objectives and recovery time objectives. Appropriate corrective actions are taken to meet the organizational requirements.	<u>CC.7.5</u> <u>CC.9.1</u> <u>A.1.3</u>	Inquired of the control owner and ascertained that the business continuity plan was performed and tested on a periodic basis, and correction actions were taken as appropriate.	No deviations noted.
			Inspected the documented testing results of the business continuity plan testing, and ascertained that the testing was performed at least annually to verify	No deviations noted.



Availability Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
			the plan's relevance and effectiveness of the established recovery strategy, action plan, recovery point objectives and recovery time objectives. Further inspected that appropriate corrective actions were taken to meet the organizational requirements, if applicable.	
ER.4.0	Okta tests its disaster and functional recovery plans on an annual basis to verify its relevance and validate the effectiveness of established recovery strategy, action plan, recovery point objectives and recovery time objectives. Appropriate corrective actions are taken to meet the organizational requirements.	<u>CC.7.5</u> <u>CC.9.1</u> <u>A.1.3</u>	Inquired of the control owner and ascertained that the disaster and functional recovery plan was performed and tested on a periodic basis.	No deviations noted.
			Inspected the documented testing results of the disaster and functional recovery plan testing, and ascertained that the testing was performed at least annually to verify the plan's relevance and effectiveness of the established recovery strategy, action plan, recovery point objectives and recovery time objectives. Further inspected that appropriate corrective actions were taken to meet the organizational requirements, if applicable.	No deviations noted.
ER.7.0	Business Impact Analysis ("BIA") is performed to understand enterprise resilience requirements and determine recovery objectives. BIA takes into consideration the criticality of the organizational processes and services and their components, including associated applications and systems.	<u>CC.7.5</u>	Inquired of the control owner and ascertained that Business Impact Analysis ("BIA") was conducted to understand enterprise resilience requirements and determine recovery objectives.	No deviations noted.
			Inspected the documented results of the Business Impact Analysis plan, and ascertained that the BIA was performed, including an impact analysis of the criticality of the organizational processes and services and their components.	No deviations noted.



Availability Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
ER.8.0	Okta monitors system capacity to enable the implementation of additional capacity, thereby helping to meet availability and continuity commitments and availability requirements.	<u>A.1.1</u>	Inquired of the control owner and ascertained that system capacity was monitored to enable the implementation of additional capacity to help meet availability and continuity commitments and availability requirements.	No deviations noted.
			Inspected the relevant configurations and ascertained that system capacity was monitored to enable implementation of additional capacity to support availability, continuity commitments, and availability requirements.	No deviations noted.
			Inspected the alert tickets for a sample of alerts related to capacity monitoring and ascertained that system capacity was monitored and assessed if additional capacity should be implemented.	No deviations noted.
ER.9.0	Backups of information are conducted and maintained. Regular testing of backup restoration is performed. Backups are retained for a specified period of time as per backup policies. Documented procedures are maintained to restore any loss of data.	<u>CC.7.4</u> <u>CC.7.5</u> <u>A.1.2</u> <u>A.1.3</u>	Inquired of the control owner and ascertained that backups of information were conducted and maintained for a specified period time as per backup policies. Further inquired the documented procedures were maintained and approved.	No deviations noted.
			Inspected the backup and restoration policy and ascertained that the backup and restoration policy was documented, maintained, and approved. Further inspected that the backup and restoration policy outlined procedures on backups and restoration of data.	No deviations noted.
			Inspected the relevant configurations of backup for the product and ascertained that the backup	No deviations noted.



Availability Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
			configuration was maintained appropriately and retained for a specified period of time as per backup policies.	
			Inspected the alert tickets for a sample of failed backups and ascertained that any failed backups were monitored and resolved in a timely manner.	No deviations noted.
			Inspected the restoration testing result and ascertained that periodic testing of backup restoration was performed.	No deviations noted.
ER.10.0	Multi-availability zone and multi-region architecture is in place for the cloud services provided which helps the organization recover from major business disruptions or disaster as per the defined recovery time objectives (RTO) and the necessary third-party service agreements are established to allow for the timely resumption of critical business processes.	<u>CC.7.4</u> <u>CC.7.5</u> <u>A.1.1</u> <u>A.1.2</u> <u>A.1.3</u>	Inquired of the control owner and ascertained that cloud services were deployed in multiple availability zones to help the organization recover from major business disruptions or disasters as per the defined recovery time objectives (RTO) and the necessary third-party service agreements were established to allow for the timely resumption of critical business processes.	No deviations noted.
			Inspected the relevant configurations and ascertained that multiple availability zones were enabled.	No deviations noted.
			Inspected the alert tickets for a sample of failed replications and ascertained that failed replications were monitored and resolved in a timely manner.	No deviations noted.



Vendor Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
TP.1.0	Okta manages third-party relationships and assesses third parties to identify inherent risks. Based on the inherent risks, Okta classifies third parties in order to protect information systems and information.	<u>CC.1.3</u>	Inquired of the control owner and ascertained that Okta had a formal process to assess and classify third parties based on inherent risks.	No deviations noted.
			Inspected the Third-Party Risk Management Policy and ascertained that a process was in place to assess and classify third parties based on inherent risks.	No deviations noted.
			Inspected the documented risk assessment results for a sample of vendors, and ascertained that the vendors were assessed and classified based on the identified inherent risks.	No deviations noted.
TP.2.0	A vendor contract is signed between Okta and contracted third-party entities, outlining their respective roles and responsibilities. The contract includes provisions for security requirements, confidentiality/non-disclosure agreements, specific obligations and exit strategies.	<u>CC.1.1</u> <u>CC.1.3</u> <u>CC.2.3</u> <u>CC.3.1</u> <u>CC.9.2</u> <u>A.1.2</u> <u>C.1.1</u>	Inquired of the control owner and ascertained that a vendor contract was signed between Okta and contracted third-party entities, outlining their respective roles and responsibilities. Further inquired that the contract included provisions for security requirements, confidentiality/non-disclosure agreements, specific obligations and exit strategies.	No deviations noted.
			Inspected the signed contract for a sample of vendors, and ascertained that the contract outlined their respective roles and responsibilities. Further inspected that the contract included provisions for security requirements, confidentiality/non-disclosure agreements, specific obligations, and exit strategies.	No deviations noted.
TP.3.0	A security due diligence process, inclusive of risk assessments to identify direct and indirect risks, is performed to assess third parties and vendors.	<u>CC.1.1</u> <u>CC.3.1</u> <u>CC.3.4</u>	Inquired of the control owner and ascertained that a security due diligence process was performed to assess new third parties and vendors.	No deviations noted.



Vendor Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
		<u>CC.9.2</u> <u>A.1.2</u> <u>C.1.1</u>	Inspected the documented vendor risk assessment report results for a sample of third parties and vendors, and ascertained that a security due diligence process, inclusive of risk assessments, were performed.	January 1, 2024 - May 31, 2024 Deviation noted. For two (2) of the 21 third parties and vendors sampled, the risk assessment was not performed. June 1, 2024 - November 30, 2024 No deviations noted.
Management Response: Management agrees that the 2 vendors in question should have been flagged for the Security review by Procurement. Security (TPRM) will take a proactive approach to deploy an integrated solution between core third party systems to provide an automated and systematic way to determine when Security (TPRM) should be engaged for new vendors to reduce the likelihood of recurrence. This has been remediated as of June 1, 2024.				
TP.4.0	Okta performs periodic monitoring of contracted third-party and vendor performance and risk and verifies whether the contracted third-party is compliant with the contractual security terms and	<u>CC.1.3</u> <u>CC.9.2</u> <u>A.1.2</u>	Inquired of the control owner and ascertained that contracted third-party and vendors underwent periodic monitoring to verify their compliance with the security terms and conditions.	No deviations noted.



Vendor Management Controls				
Control #	Controls Specified by Okta	Criteria	Test Procedures Performed by EY	Test Results
	conditions.		Inspected the documented vendor risk assessment report results for a sample of third parties and vendors and ascertained that periodic monitoring of contracted third-party and vendors performance and risk were completed. Further inspected that Okta periodically verified whether the contracted third parties and vendors were compliant with the contractual security terms and conditions.	No deviations noted.
TP.4.1	Okta performs an annual review of the SOC report of the relevant third-party and vendor.	<u>CC.1.3</u> <u>CC.9.2</u> <u>A.1.2</u>	Inquired of the control owner and ascertained that Okta performed an annual review of the SOC report of AWS.	No deviations noted.
			Inspected the result of the annual review and ascertained that Okta performed an annual review of the SOC report of AWS.	No deviations noted.



Okta's Controls Mapped to the Trust Services Security, Availability, and Confidentiality Criteria

Criteria	Criteria Description	Supporting Control
CC 1.0 Common Criteria Related to Control Environment		
CC.1.1	The entity demonstrates a commitment to integrity and ethical values.	<u>ELC-03-02</u> , <u>ELC-05-01</u> , <u>HC.2.0</u> , <u>HC.3.0</u> , <u>SP.1.0</u> , <u>SP.4.0</u> , <u>TP.2.0</u> , <u>TP.3.0</u>
CC.1.2	The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.	<u>ELC-02-01</u> , <u>ELC-02-02</u> , <u>ELC-02-03</u> , <u>ELC-02-04</u> , <u>ELC-03-01</u> , <u>SP.5.0</u>
CC.1.3	Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.	<u>SP.4.0</u> , <u>SP.5.0</u> , <u>HC.3.0</u> , <u>TP.1.0</u> , <u>TP.2.0</u> , <u>TP.4.0</u> , <u>TP.4.1</u>
CC.1.4	The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.	<u>ELC-02-01</u> , <u>ELC-02-02</u> , <u>ELC-02-03</u> , <u>ELC-02-04</u> , <u>ELC-03-01</u> , <u>SP.1.0</u> , <u>SP.4.0</u> , <u>SP.5.0</u> , <u>ELC-03-02</u> , <u>ELC-04-01</u> , <u>ELC-05-01</u> , <u>TA.1.0</u>
CC.1.5	The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.	<u>ELC-07-01</u> , <u>HC.2.0</u> , <u>HC.3.0</u> , <u>SP.1.0</u> , <u>SP.4.0</u> , <u>TA.1.0</u>
CC 2.0 Common Criteria Related to Communication and Information		
CC.2.1	The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.	<u>DP.11.0</u> , <u>CM.1.0</u> , <u>CM.2.0</u> , <u>CM.3.0</u> , <u>CM.4.0</u> , <u>CF.1.0</u> , <u>SD.3.0</u> , <u>AM.1.0</u> , <u>DS.1.0</u>
CC.2.2	The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.	<u>ELC-01-02</u> , <u>ELC-02-01</u> , <u>ELC-02-02</u> , <u>ELC-02-03</u> , <u>ELC-03-01</u> , <u>SP.1.0</u> , <u>SP.4.0</u> , <u>SP.5.0</u> , <u>ELC-03-02</u> , <u>ELC-05-01</u> , <u>HC.3.0</u> , <u>TA.1.0</u> , <u>CM.1.0</u> , <u>IR.1.0</u> , <u>IR.2.0</u> , <u>IR.4.0</u>
CC.2.3	The entity communicates with external parties regarding matters affecting the functioning of internal control.	<u>ELC-01-02</u> , <u>ELC-02-01</u> , <u>ELC-02-02</u> , <u>ELC-02-03</u> , <u>ELC-02-04</u> , <u>ELC-03-01</u> , <u>SP.1.0</u> , <u>SP.4.0</u> , <u>TP.6.0</u> , <u>CM.1.0</u> , <u>IR.1.0</u> , <u>IR.2.0</u> , <u>IR.4.0</u> , <u>TP.2.0</u>



Criteria	Criteria Description	Supporting Control
CC 3.0 Common Criteria Related to Risk Assessment		
CC.3.1	The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.	<u>ELC-02-02</u> , <u>ELC-03-01</u> , <u>ELC-07-02</u> , <u>SP.1.0</u> , <u>SP.4.0</u> , <u>SD.2.0</u> , <u>ELC-07-03</u> , <u>ELC-11-01</u> , <u>RM.2.0</u> , <u>RM.3.0</u> , <u>TP.2.0</u> , <u>TP.3.0</u>
CC.3.2	The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.	<u>SP.1.0</u> , <u>AM.1.0</u> , <u>VM.2.0</u> , <u>VM.5.0</u> , <u>RM.2.0</u> , <u>RM.3.0</u> , <u>IR.4.0</u>
CC.3.3	The entity considers the potential for fraud in assessing risks to the achievement of objectives.	<u>ELC-07-02</u> , <u>RM.2.0</u>
CC.3.4	The entity identifies and assesses changes that could significantly impact the system of internal control.	<u>ELC-02-02</u> , <u>CM.2.0</u> , <u>VM.2.0</u> , <u>VM.5.0</u> , <u>ELC-11-01</u> , <u>RM.2.0</u> , <u>TP.3.0</u>
CC 4.0 Common Criteria Related to Monitoring Activities		
CC.4.1	The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.	<u>ELC-02-04</u> , <u>ELC-17-01</u> , <u>SD.2.0</u>
CC.4.2	The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.	<u>ELC-02-04</u> , <u>ELC-07-01</u> , <u>ELC-17-01</u> , <u>ELC-11-01</u> , <u>RM.3.0</u>
CC 5.0 Common Criteria Related to Control Activities		
CC.5.1	The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.	<u>SP.1.0</u> , <u>SP.5.0</u> , <u>SD.2.0</u> , <u>ELC-11-01</u> , <u>RM.2.0</u> , <u>RM.3.0</u>
CC.5.2	The entity also selects and develops general control activities over technology to support the achievement of objectives.	<u>SP.1.0</u> , <u>HC.3.0</u> , <u>CF.1.0</u> , <u>SD.2.0</u> , <u>IM.1.0</u> , <u>IM.2.0</u> , <u>IR.2.0</u>
CC.5.3	The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.	<u>SP.1.0</u> , <u>SP.4.0</u> , <u>SP.5.0</u> , <u>ELC-03-02</u> , <u>ELC-05-01</u> , <u>HC.3.0</u>



Criteria	Criteria Description	Supporting Control
CC 6.0 Common Criteria Related to Logical and Physical Access Controls		
CC.6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	<u>IM.15.0</u> , <u>SD.2.0</u> , <u>IM.1.0</u> , <u>IM.2.0</u> , <u>IM.5.0</u> , <u>IM.7.0</u> , <u>IM.9.0</u> , <u>IM.11.0</u> , <u>IM.12.0</u> , <u>IM.13.0</u> , <u>NS.8.0</u> , <u>AM.1.0</u> , <u>DS.2.0</u> , <u>DS.4.0</u> , <u>DS.5.0</u> , <u>DS.6.0</u> , <u>NS.2.0</u> , <u>NS.3.0</u> , <u>NS.4.0</u> , <u>SP.7.0</u>
CC.6.2	Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.	<u>IM.15.0</u> , <u>IM.1.0</u> , <u>IM.2.0</u> , <u>IM.5.0</u> , <u>IM.6.0</u> , <u>IM.7.0</u> , <u>SP.7.0</u>
CC.6.3	The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.	<u>IM.15.0</u> , <u>IM.1.0</u> , <u>IM.2.0</u> , <u>IM.5.0</u> , <u>IM.6.0</u> , <u>IM.7.0</u> , <u>SP.7.0</u>
CC.6.4	The entity restricts physical access to facilities and protected information assets (for example, data center facilities, back-up media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.	<u>IM.5.0</u> , <u>AM.1.0</u> , <u>AM.9.0</u> , <u>AM.10.0</u>
CC.6.5	The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.	<u>AM.1.0</u> , <u>AM.9.0</u> , <u>AM.10.0</u>
CC.6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.	<u>IM.9.0</u> , <u>IM.11.0</u> , <u>IM.13.0</u> , <u>NS.8.0</u> , <u>DS.6.0</u> , <u>NS.2.0</u> , <u>NS.3.0</u> , <u>NS.4.0</u>
CC.6.7	The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.	<u>NS.8.0</u> , <u>AM.3.0</u> , <u>AM.6.0</u> , <u>AM.9.0</u> , <u>AM.10.0</u> , <u>DS.2.0</u> , <u>DS.4.0</u> , <u>DS.5.0</u> , <u>DS.6.0</u> , <u>CF.5.0</u> , <u>CF.8.0</u>
CC.6.8	The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.	<u>CM.1.0</u> , <u>CM.2.0</u> , <u>CM.3.0</u> , <u>CM.4.0</u> , <u>AM.1.0</u> , <u>AM.3.0</u> , <u>VM.5.0</u> , <u>CF.8.0</u> , <u>IR.1.0</u> , <u>NS.2.0</u>



Criteria	Criteria Description	Supporting Control
CC7.0 Common Criteria Related to System Operations		
CC.7.1	To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.	<u>CF.1.0</u> , <u>SM.1.0</u> , <u>SM.2.0</u> , <u>SM.7.0</u> , <u>VM.5.0</u> , <u>VM.6.0</u> , <u>CF.2.0</u> , <u>IR.1.0</u> , <u>IR.5.0</u>
CC.7.2	The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.	<u>SM.1.0</u> , <u>SM.2.0</u> , <u>SM.7.0</u> , <u>VM.5.0</u> , <u>IR.1.0</u> , <u>IR.2.0</u> , <u>IR.4.0</u> , <u>NS.2.0</u> , <u>NS.4.0</u>
CC.7.3	The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.	<u>VM.5.0</u> , <u>VM.6.0</u> , <u>IR.1.0</u> , <u>IR.2.0</u> , <u>IR.4.0</u> , <u>IR.5.0</u> , <u>NS.2.0</u>
CC.7.4	The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.	<u>VM.5.0</u> , <u>VM.6.0</u> , <u>IR.1.0</u> , <u>IR.2.0</u> , <u>IR.4.0</u> , <u>IR.5.0</u> , <u>ER.9.0</u> , <u>ER.10.0</u>
CC.7.5	The entity identifies, develops, and implements activities to recover from identified security incidents.	<u>IR.1.0</u> , <u>IR.2.0</u> , <u>IR.4.0</u> , <u>IR.5.0</u> , <u>ER.1.0</u> , <u>ER.3.0</u> , <u>ER.2.2</u> , <u>ER.4.0</u> , <u>ER.7.0</u> , <u>ER.9.0</u> , <u>ER.10.0</u>
CC 8.0 Common Criteria Related to Change Management		
CC.8.1	The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.	<u>CM.1.0</u> , <u>CM.2.0</u> , <u>CM.3.0</u> , <u>CM.4.0</u> , <u>CF.1.0</u> , <u>AM.1.0</u> , <u>VM.5.0</u> , <u>VM.6.0</u> , <u>CF.2.0</u> , <u>CF.5.0</u>
CC 9.0 Common Criteria Related to Risk Mitigation		
CC.9.1	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.	<u>ER.1.0</u> , <u>ER.2.0</u> , <u>ER.3.0</u> , <u>ER.4.0</u>
CC.9.2	The entity assesses and manages risks associated with vendors and business partners.	<u>TP.6.0</u> , <u>TP.2.0</u> , <u>TP.3.0</u> , <u>TP.4.0</u> , <u>TP.4.1</u>



Criteria	Criteria Description	Supporting Control
A 1.0 Criteria Related to Availability		
A.1.1	The entity maintains, monitors, and evaluates current processing capacity and use of system components (infrastructure, data, and software) to manage capacity demand and to enable the implementation of additional capacity to help meet its objectives.	<u>ER.8.0</u> , <u>ER.10.0</u>
A.1.2	The entity authorizes, designs, develops or acquires, implements, operates, approves, maintains, and monitors environmental protections, software, data back-up processes, and recovery infrastructure to meet its objectives.	<u>ER.1.0</u> , <u>ER.9.0</u> , <u>ER.10.0</u> , <u>TP.2.0</u> , <u>TP.3.0</u> , <u>TP.4.0</u> , <u>TP.4.1</u>
A.1.3	The entity tests recovery plan procedures supporting system recovery to meet its objectives.	<u>ER.1.0</u> , <u>ER.2.0</u> , <u>ER.3.0</u> , <u>ER.4.0</u> , <u>ER.9.0</u> , <u>ER.10.0</u>
C 1.0 Criteria Related to Confidentiality		
C.1.1	The entity identifies and maintains confidential information to meet the entity's objectives related to confidentiality.	<u>IM.2.0</u> , <u>AM.9.0</u> , <u>DS.1.0</u> , <u>DS.4.0</u> , <u>TP.2.0</u> , <u>TP.3.0</u> , <u>DP.11.0</u>
C.1.2	The entity disposes of confidential information to meet the entity's objectives related to confidentiality.	<u>AM.9.0</u> , <u>DP.11.0</u>